Arquitectura de Solución
Banca por Internet

Diseño de una plataforma de banca digital para la entidad BP
Modelo C4 completo, decisiones justificadas y despliegue sobre AWS

Elaborado por	David Palma
Rol	Arquitecto de Soluciones
Notación	Modelo C4: contexto, contenedores, componentes y código
Nube	Amazon Web Services
Versión	1.0

El documento se organiza en dos partes. La Parte I recoge el problema tal como fue planteado y lo traduce en requisitos numerados. La Parte II desarrolla la solución: las cuatro vistas del modelo C4, el registro de decisiones con su justificación, y las vistas de despliegue, seguridad, continuidad, observabilidad y costos.

Contenido

	PARTE I. EL PROBLEMA
1.	Enunciado y alcance
2.	Requisitos identificados
3.	Restricciones y supuestos
	PARTE II. LA SOLUCIÓN
4.	Resumen de la propuesta
5.	Nivel 1: diagrama de contexto
6.	Nivel 2: diagrama de contenedores
7.	Nivel 3: diagramas de componentes
8.	Nivel 4: diagramas de código
9.	Flujos principales
10.	Arquitectura de las aplicaciones de canal
11.	Arquitectura de autenticación y autorización
12.	Arquitectura de integración con el onboarding
13.	Diseño de la solución de auditoría
14.	Arquitectura de acceso a datos
15.	Integración con servicios externos
16.	Vista de despliegue, alta disponibilidad y recuperación
17.	Catálogo de servicios de AWS utilizados
18.	Vista de seguridad
19.	Observabilidad, excelencia operativa y auto-reparación
20.	Marco normativo y estándares aplicables
21.	Manejo de costos
22.	Registro de decisiones de arquitectura
23.	Patrones aplicados
24.	Riesgos y mitigaciones
25.	Trazabilidad: requisito, decisión y vista

PARTE I | EL PROBLEMA

Enunciado, requisitos derivados, restricciones y supuestos.

1. Enunciado y alcance

Se solicita diseñar la arquitectura de un sistema de banca por internet para la entidad **BP**. A través de este sistema los usuarios podrán acceder al histórico de cuentas y realizar transferencias y pagos entre cuentas propias e interbancarias.

> *La información del cliente se toma de dos sistemas: una plataforma **Core**, que contiene información básica de cliente, movimientos y productos, y un **sistema independiente** que complementa la información del cliente cuando se requieren datos en detalle.*

El alcance del diseño cubre los canales, la capa de integración, los servicios de dominio, la persistencia, la mensajería, la seguridad, el despliegue en nube y la operación. No cubre la construcción del Core ni la del sistema complementario, que se consumen como existentes.

2. Requisitos identificados

Del enunciado y de las consideraciones se desprenden los siguientes requisitos. Cada uno se rastrea en la sección 24 hasta la decisión y la vista que lo resuelven.

#	Requisito	Origen
R1	Consultar el histórico de cuentas del cliente.	Enunciado
R2	Realizar transferencias y pagos entre cuentas propias e interbancarias.	Enunciado
R3	Unificar la información del cliente proveniente del Core y del sistema complementario.	Enunciado
R4	Notificar al usuario los movimientos realizados, con un mínimo de dos sistemas de envío.	Enunciado y norma
R5	Disponer de dos aplicaciones de canal: una SPA y una aplicación móvil multiplataforma, justificando el marco elegido entre al menos dos opciones.	Enunciado
R6	Autenticar ambas aplicaciones mediante un servicio bajo el estándar OAuth 2.0, recomendando el flujo adecuado.	Enunciado
R7	Permitir el onboarding de nuevos clientes en la aplicación móvil usando reconocimiento facial, y habilitar luego el ingreso por usuario y clave, huella u otro método.	Enunciado
R8	Registrar en una base de datos de auditoría todas las acciones del cliente.	Enunciado
R9	Proveer un mecanismo de persistencia de información para clientes frecuentes, resuelto con patrones de diseño.	Enunciado
R10	Exponer una capa de integración con API Gateway que consuma los servicios según el tipo de transacción: datos básicos, movimientos y transferencias, con libertad para añadir más.	Enunciado
R11	Cumplir el marco normativo aplicable a entidades financieras.	Consideraciones
R12	Garantizar alta disponibilidad, tolerancia a fallos y recuperación ante desastres.	Consideraciones
R13	Garantizar seguridad, monitoreo, excelencia operativa y auto-reparación.	Consideraciones
R14	Desplegar sobre infraestructura en nube (AWS o Azure) garantizando baja latencia.	Consideraciones
R15	Plantear una arquitectura desacoplada, con elementos reutilizables y cohesionados.	Consideraciones

#	Requisito	Origen
R16	Desarrollar el modelo bajo C4 hasta el nivel de componentes.	Consideraciones

3. Restricciones y supuestos

3.1 Restricciones tomadas del enunciado

Restricción	Consecuencia para el diseño
La información del cliente vive repartida en dos sistemas.	Hace falta un servicio que unifique y una regla explícita de precedencia por campo. No se expone la división al canal.
El servicio de autenticación ya existe como producto corporativo y solo se configura.	No se construye un proveedor de identidad: se configura y se define el flujo. El diseño sí aporta los controles propios del banco alrededor.
La notificación debe usar al menos dos sistemas de envío.	No es redundancia opcional: la conmutación entre proveedores y la conciliación de entrega entran en el alcance.
El onboarding ocurre en la aplicación móvil con reconocimiento facial.	La captura es móvil; la verificación y la decisión son de servidor. La app nunca decide si el rostro coincide.
La capa de integración se articula sobre un API Gateway.	El gateway es punto único de entrada, pero no compone ni contiene regla de negocio.
Se parte de tres servicios y se permite añadir más.	Se añaden cuatro servicios de dominio más, justificados por responsabilidad y no por simetría.

3.2 Supuestos

Supuesto	Por qué es razonable	Si no se cumple
El Core expone servicios consultables en línea con un tiempo de respuesta acotado.	Es la condición mínima para una banca en línea; el enunciado lo presenta como fuente de movimientos.	Habría que replicar más agresivamente y aceptar rezago en el saldo mostrado.
El Core admite operaciones de débito y abono invocables desde la plataforma.	Sin ello no existiría la transferencia que el enunciado pide.	La transferencia pasaría a diferido por archivo, con otra experiencia de usuario.
El sistema complementario es consultable por servicio o replicable.	El enunciado lo describe como un sistema independiente que complementa el dato.	Se usaría replicación por archivo hacia la zona de datos.
El producto de identidad corporativo soporta OAuth 2.0 con PKCE y OIDC.	Es la línea base de cualquier producto de identidad vigente.	Se añadiría un intermediario de identidad, con el costo de un salto más.
La jurisdicción exige notificación de movimientos y retención de auditoría plurianual. *Por confirmar.*	Es el común denominador de la regulación bancaria en la región.	Cambiarían plazos de retención y contenido de los avisos, no la arquitectura.

PARTE II | LA SOLUCIÓN

Vistas del modelo C4, despliegue, seguridad, continuidad, observabilidad, normativa, costos y registro de decisiones.

4. Resumen de la propuesta

Se propone una plataforma de banca digital **desacoplada por dominio**, desplegada sobre AWS en contenedores, con dos canales que consumen una capa de integración común y servicios que se comunican por interfaz publicada y por eventos.

4.1 Las cuatro decisiones que sostienen el resto

#	Decisión	Qué resuelve
1	Un BFF por canal detrás de un API Gateway único.	Permite que la web y el móvil evolucionen a ritmos distintos sin tocar el dominio, y concentra la protección en un solo punto de entrada.
2	Servicios de dominio con almacenamiento propio y comunicación por eventos.	Desacopla el ritmo de cambio y permite escalar la consulta de movimientos, que concentra el tráfico, sin arrastrar a transferencias.
3	Transferencias como saga con compensación, idempotencia y outbox.	Hace consistente una operación que cruza el Core y la red interbancaria sin transacción común, y evita el doble débito por reintento.
4	Auditoría de solo anexo con hash encadenado y bloqueo de objeto.	Convierte la bitácora en prueba: ningún registro se puede alterar ni borrar, ni siquiera con credenciales de administrador.

4.2 Cómo se responde cada problema planteado

Problema del enunciado	Respuesta de la arquitectura
Información del cliente repartida en dos sistemas.	Servicio de Clientes con capa anticorrupción y fusionador de perfil con precedencia explícita por campo.
Histórico de cuentas con buen tiempo de respuesta.	Resolvedor de rango: lo reciente va al Core, lo antiguo a la réplica y lo repetido a la caché.
Transferencias propias e interbancarias.	Saga con compensación por paso, clave de idempotencia obligatoria y mensajería ISO 20022 hacia la red.
Notificación obligatoria de movimientos.	Dos proveedores con corte de circuito, conmutación automática y conciliador que detecta lo no entregado.
Autenticación bajo OAuth 2.0.	Authorization Code con PKCE para ambos canales, que son clientes públicos, con segundo factor adaptativo por riesgo.
Onboarding con reconocimiento facial.	Trámite con máquina de estados; detección de vida y comparación facial como controles separados; credencial creada en el proveedor de identidad.
Auditoría de todas las acciones.	Bitácora de solo anexo, con integridad verificable y archivo legal inmutable.
Persistencia para clientes frecuentes.	Cache-aside, observador para invalidar por evento, vista materializada, estrategia de precarga y decorador para degradar sin caerse.
Capa de integración con API Gateway.	Gateway que autentica, protege, limita y enruta por tipo de transacción; la composición vive en los BFF.

5. Nivel 1: diagrama de contexto

Destinado a lectura no técnica. Muestra quién usa el sistema, con qué sistemas internos del banco se relaciona y de qué servicios de terceros depende, con una descripción breve en cada conexión.

Actor o sistema	Relación con la plataforma
Cliente bancario	Consulta saldos y movimientos, y ordena transferencias y pagos.
Persona que se vincula	Completa la vinculación digital desde la aplicación móvil.
Oficial de cumplimiento	Consulta la bitácora de acciones y genera reportes.
Operaciones y soporte	Observa el estado del servicio y sus indicadores.
Core Bancario	Entrega datos básicos, productos y movimientos; ejecuta débitos y abonos.
Sistema Complementario de Cliente	Entrega el detalle del cliente que el Core no contiene.
Proveedor de identidad OAuth 2.0	Autentica al usuario y emite los token; es producto corporativo existente.
SIEM corporativo	Recibe los eventos de seguridad para correlación.
Proveedor de notificaciones A y Proveedor de notificaciones B	Entregan los avisos de movimiento por push, SMS y correo.
Verificación de identidad	Detecta prueba de vida y compara el rostro con el documento.
Validación documental	Contrasta el documento contra fuentes oficiales.
Red interbancaria / ACH	Liquida las transferencias hacia otras entidades.

Nivel 1 - Diagrama de contexto: Banca Digital BP

Quién usa el sistema y con qué sistemas del banco y de terceros se relaciona

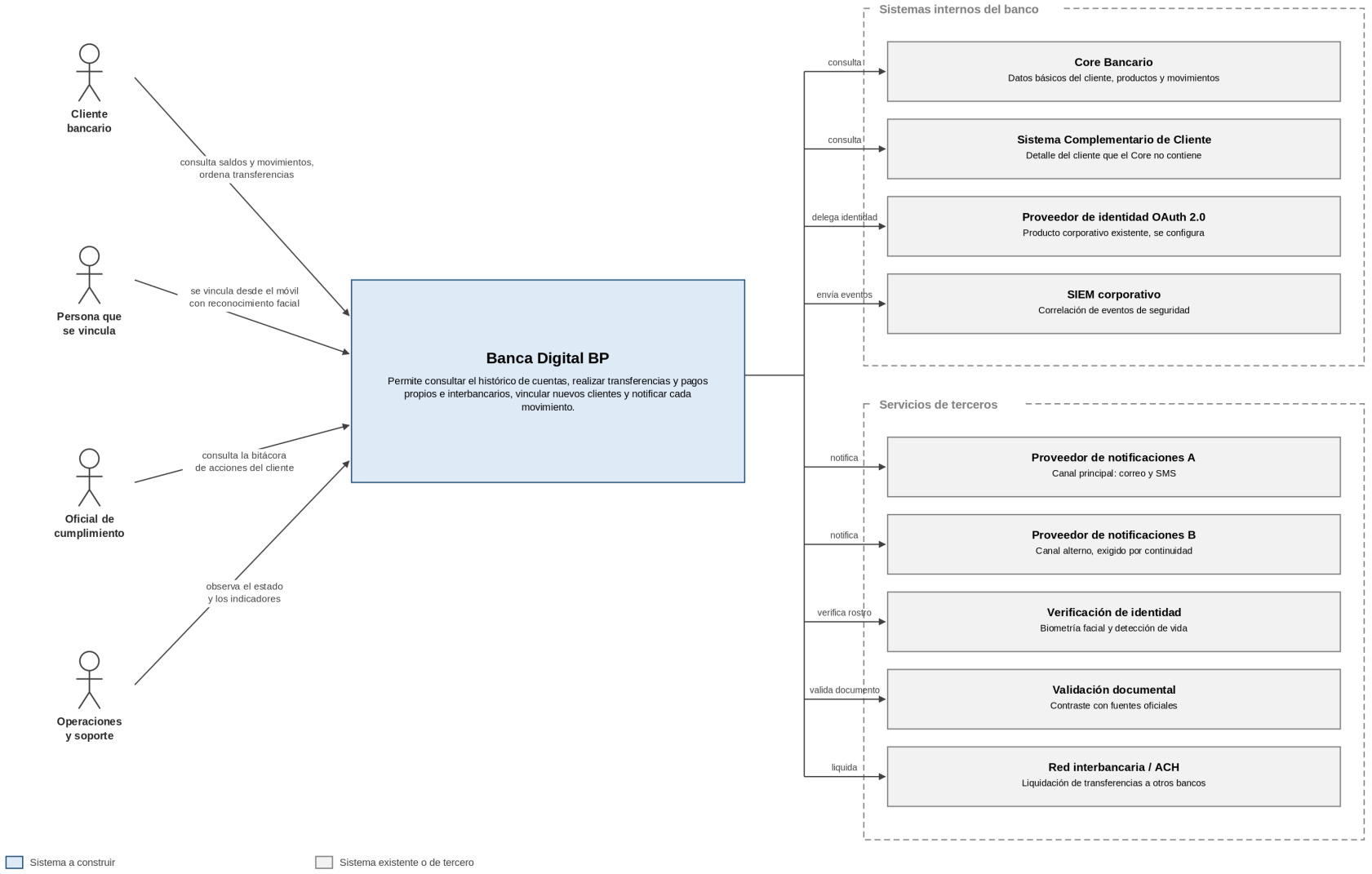


Figura 1. Nivel 1 - Diagrama de contexto

6. Nivel 2: diagrama de contenedores

Destinado a lectura técnica. Muestra las unidades desplegables, los almacenes de datos y la mensajería, con los servicios gestionados de AWS identificados pero sin entrar en detalle.

Contenedor	Tecnología	Responsabilidad
SPA Web	Angular, S3 y CloudFront	Experiencia web; no contiene regla de negocio.
App Móvil	Flutter, iOS y Android	Experiencia móvil, captura de vinculación y biometría local.
API Gateway	Amazon API Gateway y AWS WAF	Entrada única: autentica, protege, limita y enruta.
BFF Web	ECS Fargate	Compone respuestas a la medida de la pantalla web.
BFF Móvil	ECS Fargate	Compone respuestas livianas para red móvil.
Servicio de Clientes	ECS Fargate y Aurora	Unifica Core y sistema complementario.
Servicio de Movimientos	ECS Fargate y Redis	Histórico con resolución por rango.
Servicio de Transferencias	ECS Fargate, Step Functions y Aurora	Orquesta la saga y sus compensaciones.
Servicio de Notificaciones	ECS Fargate y SQS	Entrega por dos proveedores y concilia.
Servicio de Onboarding	ECS Fargate y Step Functions	Conduce el trámite de vinculación.
Servicio de Auditoría	ECS Fargate, DynamoDB y S3	Bitácora inmutable y consulta.
Servicio de Perfil Frecuente	ECS Fargate y Redis	Contexto precargado del cliente recurrente.
Bus de eventos y colas	EventBridge y SQS con cola de descarte	Desacopla a productores de consumidores.
Adaptadores de integración	ECS Fargate	Capa anticorrupción hacia Core, ACH y terceros.

6.1 Los servicios de la capa de integración

El enunciado parte de **tres servicios principales** y deja libertad para agregar más si mejoran el rendimiento o la respuesta de información al cliente. Se agregan cuatro, y cada uno se justifica por una responsabilidad que de otro modo quedaría huérfana o mal ubicada.

Servicio	Origen	Responsabilidad	Por qué existe
Consulta de datos básicos	Del enunciado	Unifica el perfil del Core y del sistema complementario.	Es uno de los tres servicios declarados. Sin él, el canal tendría que conocer las dos fuentes.
Consulta de movimientos	Del enunciado	Histórico de cuentas con resolución por rango.	Es el servicio con más tráfico; separarlo permite escalarlo sin arrastrar al resto.
Transferencias	Del enunciado	Orquesta la operación propia e interbancaria.	Es el único con escritura de dinero: concentra el riesgo y la regulación.
Notificaciones	**Agregado**	Entrega por dos proveedores, con conmutación y conciliación.	Es obligación normativa, no una función de transferencias. Si viviera dentro de ella, la caída de un proveedor afectaría a la operación.
Onboarding	**Agregado**	Conduce la vinculación digital como trámite con estado.	El enunciado lo pide expresamente y su ciclo de vida es de minutos u horas, no de milisegundos: no cabe en un servicio transaccional.

Servicio	Origen	Responsabilidad	Por qué existe
Auditoría	**Agregado**	Bitácora inmutable de todas las acciones.	El enunciado pide registrar todas las acciones del cliente. Centralizarlo evita que cada servicio invente su propio formato y su propio nivel de integridad.
Perfil Frecuente	**Agregado**	Precarga y mantiene el contexto del cliente recurrente.	Es la respuesta directa a la mejora de rendimiento y de respuesta de información que el enunciado invita a proponer.

Tres servicios más se consideraron y se descartaron, para dejar claro que la lista no creció por inercia: un servicio de productos (su dato ya lo entrega el de clientes y separarlo duplicaría llamadas), uno de reportes (lo resuelve la zona analítica sin un servicio en línea) y uno de pagos de servicios (está fuera del alcance declarado).

6.2 Desacoplamiento, cohesión y reutilización

El enunciado pide una arquitectura desacoplada, con elementos reutilizables y cohesionados que puedan servir a componentes futuros. Estos son los mecanismos concretos que lo hacen cierto, y no solo declarado.

Propiedad	Mecanismo	Prueba de que se cumple
Desacoplamiento temporal	Comunicación por eventos a través de EventBridge y SQS.	El Servicio de Notificaciones puede estar caído y la transferencia se completa igual: el evento espera en la cola.
Desacoplamiento de despliegue	Base de datos por servicio y contratos versionados.	Ningún servicio lee la tabla de otro, así que cada uno se despliega sin coordinar ventana con los demás.
Desacoplamiento tecnológico	Puertos y adaptadores en cada integración externa.	Cambiar de proveedor de biometría o de notificaciones es sustituir un adaptador, no tocar el dominio.
Desacoplamiento de canal	Un BFF por canal sobre un dominio común.	Agregar un tercer canal (por ejemplo un portal de asesores) es agregar un BFF, sin modificar ningún servicio.
Cohesión funcional	Frontera por contexto delimitado y por razón de cambio.	Todo lo que cambia cuando cambia la regulación de pagos está dentro de Transferencias, y nada más lo está.
Reutilización entre dominios	Servicios transversales consumibles por cualquier componente futuro.	Auditoría, Notificaciones, Perfil Frecuente y los adaptadores no conocen a sus consumidores: se suscriben o exponen interfaz.

La prueba práctica del desacoplamiento es esta: **agregar un producto nuevo, por ejemplo pago de servicios, no exige modificar ningún servicio existente.** Se crea el servicio, se suscribe a los eventos que le interesan, publica los suyos, y Auditoría y Notificaciones lo cubren sin cambio alguno porque nunca supieron quién publicaba.

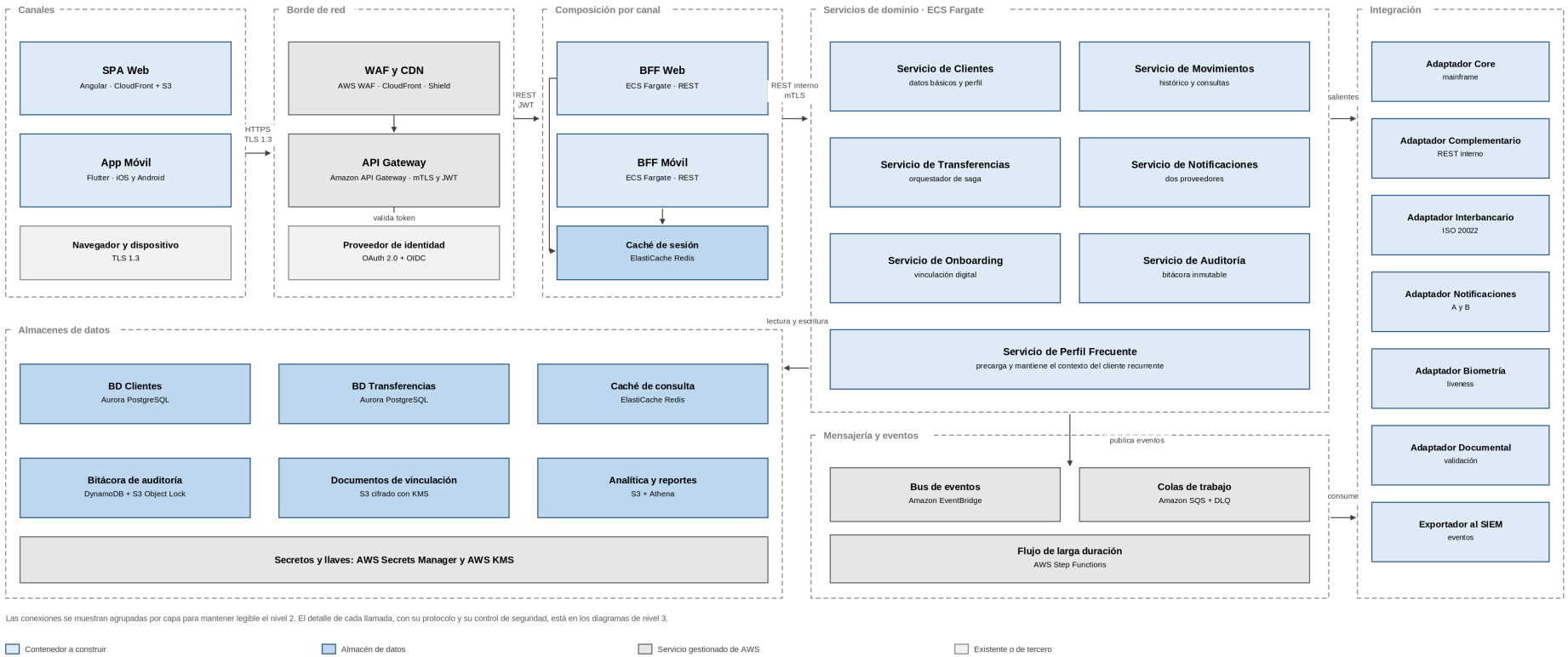


Figura 2. Nivel 2 - Diagrama de contenedores

7. Nivel 3: diagramas de componentes

Esta es la vista central del entregable. Se documenta **un diagrama por cada contenedor construido**, con los componentes internos, el protocolo de cada conexión y el control de seguridad que la protege.

7.1 Criterio de descomposición

Los componentes no se repartieron por simetría. Cada contenedor se partió aplicando tres reglas:

- **Una sola razón para cambiar.** Si dos responsabilidades cambian por motivos distintos y en momentos distintos, son componentes distintos. Por eso la detección de vida y la comparación facial están separadas: una responde a la evolución del fraude y la otra a la calidad del documento.
- **Nombres del dominio, no de la tecnología.** Un componente llamado «servicio REST» no dice nada; «resolvedor de rango» sí dice qué decide.
- **Toda dependencia externa se aísla.** Cada sistema de terceros entra por un componente dedicado, para que una restricción ajena no condicione el diseño interno.

7.2 Componentes por contenedor

Contenedor	Componentes	Componente crítico
SPA Web	Shell, módulo de autenticación, guardia de rutas, módulos de cuentas, movimientos y transferencias, capa de estado, cliente HTTP, telemetría.	Módulo de autenticación: el token vive en memoria, nunca en almacenamiento local.
App Móvil	Presentación, autenticación, vinculación, biometría del dispositivo, almacén seguro, módulo transaccional, cliente HTTP, caché cifrada, escudo de integridad.	Almacén seguro: la clave privada no sale del enclave.
BFF Web	Controladores, validador de token, agregador de vistas, clientes de dominio, caché de respuesta, mapeador de salida, limitador, emisor de auditoría, correlación.	Agregador de vistas: compone varias llamadas en una.
BFF Móvil	Controladores, validador de token, agregador de pantalla, compresor de carga útil, gestor de registro push, verificador de integridad, clientes de dominio, emisor de auditoría, correlación.	Compresor de carga útil: menos campos y menos latencia en red móvil.
API Gateway	Terminación TLS, reglas de WAF, autorizador, limitador y cuota, enrutador por tipo de transacción, transformador, registro de acceso, caché, interruptor de tráfico.	Autorizador: valida el token antes de que la petición entre a la red privada.
Servicio de Clientes	API, resolvedor de perfil, cliente del Core, cliente del complementario, fusionador, capa anticorrupción, caché de perfil, repositorio, emisor de eventos.	Capa anticorrupción: el modelo del mainframe no se filtra al dominio.
Servicio de Movimientos	API, resolvedor de rango, cliente del Core, lector de réplica, caché de consulta, normalizador, enriquecedor, exportador de extracto, emisor de eventos.	Resolvedor de rango: evita mandar toda consulta histórica al mainframe.
Servicio de Transferencias	API, validador de orden, motor de límites, evaluador de riesgo, orquestador de saga, registro de idempotencia, cliente del Core, cliente interbancario, emisor de eventos.	Orquestador de saga: cada paso tiene su compensación declarada.
Servicio de Notificaciones	Consumidor de eventos, motor de plantillas, resolvedor de canal, selector de proveedor, corte de circuito, control de duplicados, cola de reintento, registro de entrega, conciliador.	Conciliador de entrega: detecta lo que quedó sin notificar.
Servicio de Onboarding	API, máquina de estados, captura documental, verificador de vida, comparador facial, validador de identidad, evaluador de riesgo, registrador de credencial, almacén de evidencia.	Verificador de vida: es el único control que detiene el ataque con fotografía.

Contenedor	Componentes	Componente crítico
Autenticación	Servidor de autorización, punto de autorización con PKCE, punto de token, gestor de métodos, evaluador de riesgo de sesión, segundo factor adaptativo, registro de dispositivos, gestor de refresco, publicador de llaves.	Evaluador de riesgo de sesión: decide cuándo exigir el segundo factor.
Servicio de Auditoría	Receptor, validador de esquema, enriquecedor de contexto, sellador de integridad, escritor, bitácora operativa, archivador legal, API de consulta, verificador de cadena.	Sellador de integridad: encadena el hash del registro anterior.
Servicio de Perfil Frecuente	API de contexto, detector de recurrencia, estrategia de precarga, gestor de caché, caché distribuida, invalidador por evento, constructor de vista, repositorio de preferencias, degradador elegante.	Invalidador por evento: reduce la ventana de dato obsoleto a segundos.

7.3 Componentes transversales

Tres capacidades no pertenecen a un contenedor sino a todos, y por eso no se repiten en cada diagrama:

Capacidad	Cómo se resuelve
Observabilidad	Identificador de correlación propagado en cada llamada y en cada evento, métricas por componente y registro estructurado sin dato sensible.
Configuración y secretos	Externalizada por ambiente; credenciales en Secrets Manager con rotación, nunca en la imagen ni en el repositorio.
Resiliencia	Reintento con retroceso exponencial, corte de circuito por dependencia externa, mamparo por tipo de carga e idempotencia por clave de operación.

7.4 Contratos entre contenedores

Cada flecha que cruza una frontera de contenedor es un contrato versionado. Son los que permiten repartir el trabajo entre equipos y desplegar por separado.

Origen	Destino	Contrato
BFF	Servicio de Clientes	Perfil unificado: identificación, productos y preferencias de contacto.
BFF	Servicio de Movimientos	Página de movimientos por cursor, con rango y filtros.
BFF	Servicio de Transferencias	Orden con clave de idempotencia obligatoria.
Transferencias	Bus de eventos	Transferencia completada o compensada, con su motivo.
Bus de eventos	Notificaciones	Hecho notificable con el identificador de la operación.
Todos	Auditoría	Evento de acción: quién, qué, cuándo, desde dónde y con qué resultado.
Onboarding	Proveedor de identidad	Alta de credencial con el nivel de garantía alcanzado.

7.5 Protocolos de comunicación y controles de seguridad por tramo

La hoja de recomendaciones pide que el diagrama de componentes muestre los protocolos de comunicación con su seguridad. Cada diagrama de nivel 3 los rotula en sus conexiones y los resume al pie; esta tabla los consolida.

Tramo	Protocolo	Autenticación	Cifrado y controles
Cliente a borde	HTTPS sobre HTTP/2	Token JWT en el encabezado Authorization	TLS 1.3; en móvil además fijado de certificado; política de seguridad de contenido estricta en la web.

Tramo	Protocolo	Autenticación	Cifrado y controles
Canal a proveedor de identidad	HTTPS, OAuth 2.0 y OpenID Connect	Código de autorización con PKCE (S256) y Pushed Authorization Request	TLS 1.3; el verificador nunca viaja en la redirección; estado contra falsificación de petición.
Borde a BFF	HTTP/2 por VPC Link privado	mTLS con certificado de carga de trabajo	Tráfico que no sale de la nube privada; el JWT ya fue validado en el gateway.
BFF a servicios de dominio	REST/JSON sobre HTTP/2	mTLS e identidad de rol de tarea	Subred privada sin salida a Internet; grupos de seguridad cerrados por servicio.
Servicio a base de datos	Protocolo nativo del motor sobre TLS	Autenticación por rol de IAM, sin contraseña estática	Cifrado en reposo con llave dedicada; credenciales rotadas por el gestor de secretos.
Servicio a caché	RESP sobre TLS	Token de autenticación gestionado	Cifrado en tránsito y en reposo; la caché nunca guarda dato sensible en claro.
Servicio a bus de eventos	API del bus sobre HTTPS	Rol de tarea con permiso de publicación únicamente	Cifrado en tránsito y en reposo; esquema del evento validado contra el registro.
Plataforma al Core	Servicio del Core sobre enlace dedicado	mTLS y credencial de servicio rotada	Enlace privado sin tránsito por Internet; tiempo de espera, corte de circuito y mamparo de conexiones.
Plataforma a la red interbancaria	ISO 20022 sobre canal privado	mTLS y firma del mensaje	Enlace privado o VPN; idempotencia por referencia y conciliación diaria de lo liquidado.
Plataforma a proveedor de notificaciones A y B	API del proveedor sobre HTTPS	Credencial rotada por el gestor de secretos	TLS 1.3; corte de circuito por proveedor; control de duplicados antes de enviar.
Plataforma a biometría y validación documental	API del proveedor sobre HTTPS	Credencial rotada y restringida por origen	TLS 1.3; la imagen sube por URL prefirmada de corta vigencia, no por el cuerpo de la petición.
Plataforma al SIEM	Exportación de eventos	Rol con permiso de solo escritura	Canal unidireccional: el SIEM recibe y nunca consulta hacia adentro.

Nivel 3 - Componentes: SPA Web

Angular distribuido desde S3 por CloudFront · patrón: arquitectura en capas con módulos por dominio

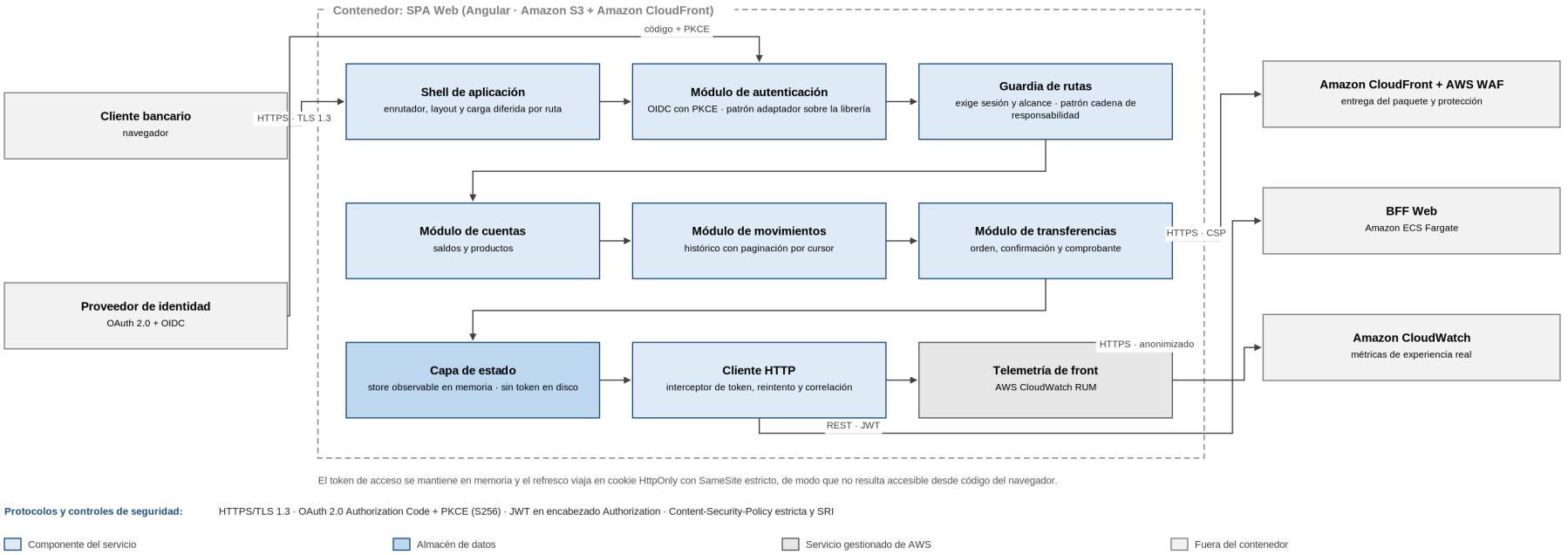


Figura 3. Nivel 3 - Componentes de la SPA Web

Nivel 3 - Componentes: App Móvil

Flutter para iOS y Android · patrón: puertos y adaptadores sobre las interfaces nativas

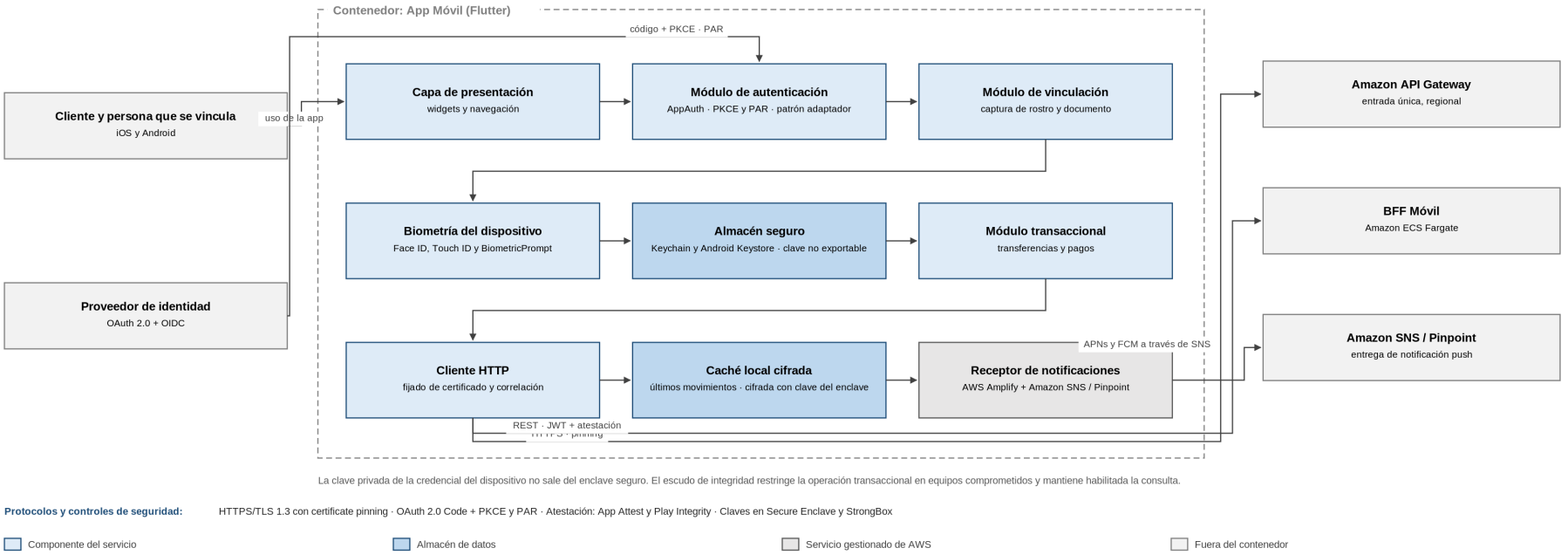


Figura 4. Nivel 3 - Componentes de la App Móvil

Nivel 3 - Componentes: capa de integración (API Gateway)

Punto único de entrada · patrones: API Gateway, limitación de tasa y despliegue canario

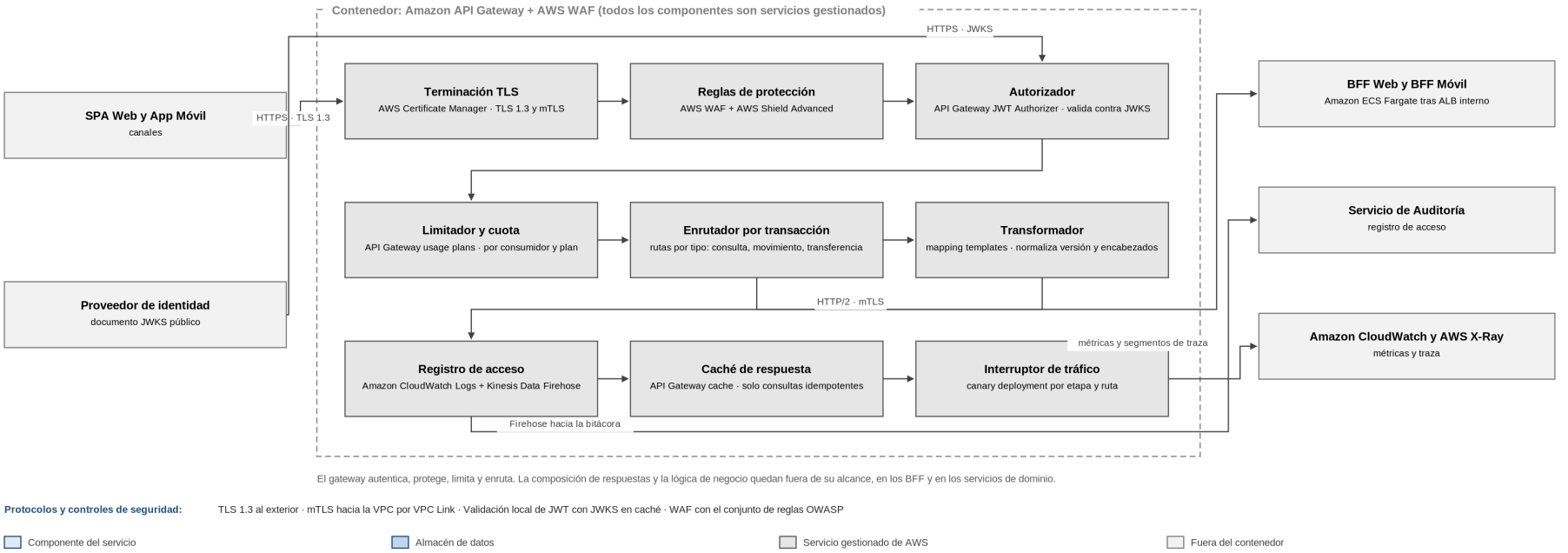


Figura 5. Nivel 3 - Componentes de la capa de integración (API Gateway)

Nivel 3 - Componentes: BFF Web

Composición para la pantalla web · patrones: BFF, agregador, outbox y corte de circuito

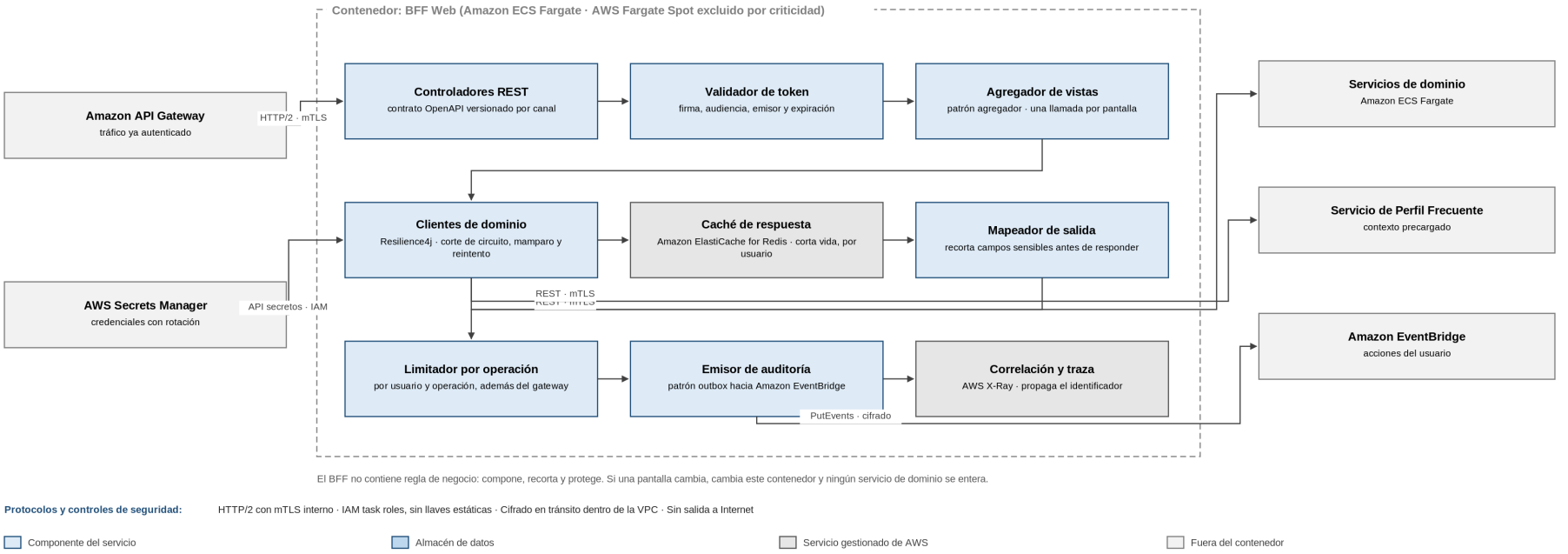


Figura 6. Nivel 3 - Componentes del BFF Web

Nivel 3 - Componentes: BFF Móvil

Composición para red móvil · patrones: BFF, agregador y compresión de carga útil

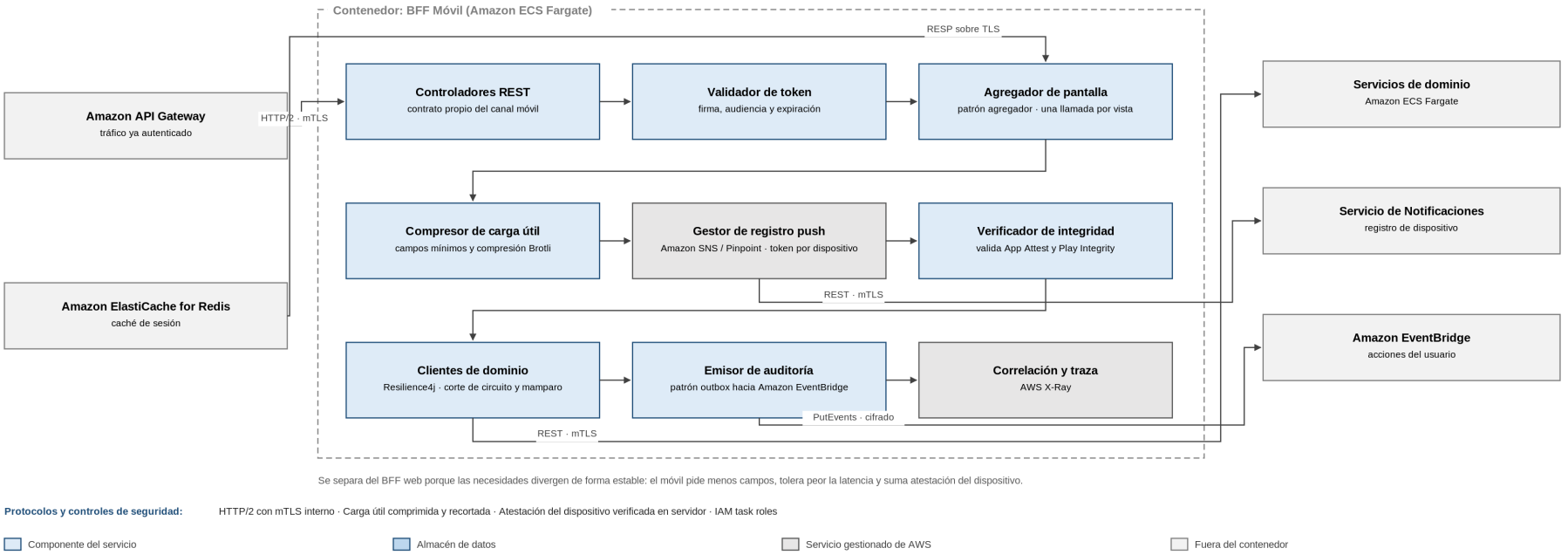


Figura 7. Nivel 3 - Componentes del BFF Móvil

Nivel 3 - Componentes: Servicio de Clientes

Unifica Core y sistema complementario · patrones: capa anticorrupción, repositorio y outbox

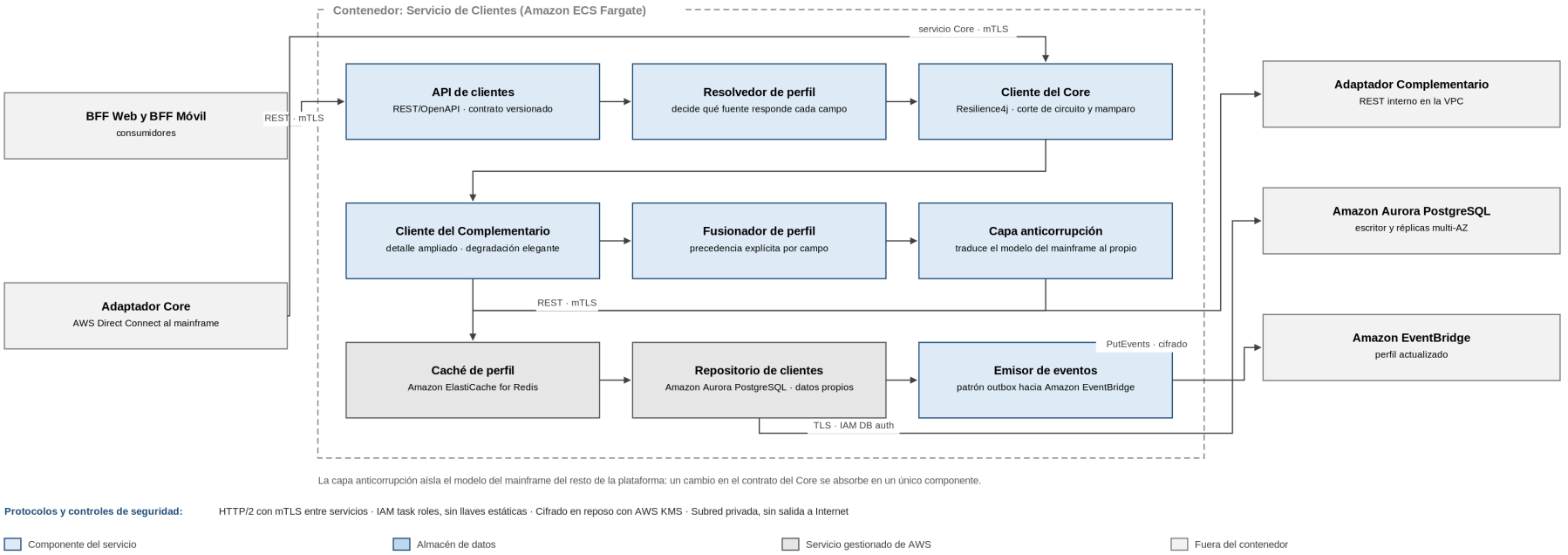


Figura 8. Nivel 3 - Componentes del Servicio de Clientes

Nivel 3 - Componentes: Servicio de Movimientos

Histórico con baja latencia · patrones: CQRS en lectura, cache-aside y resolución por rango

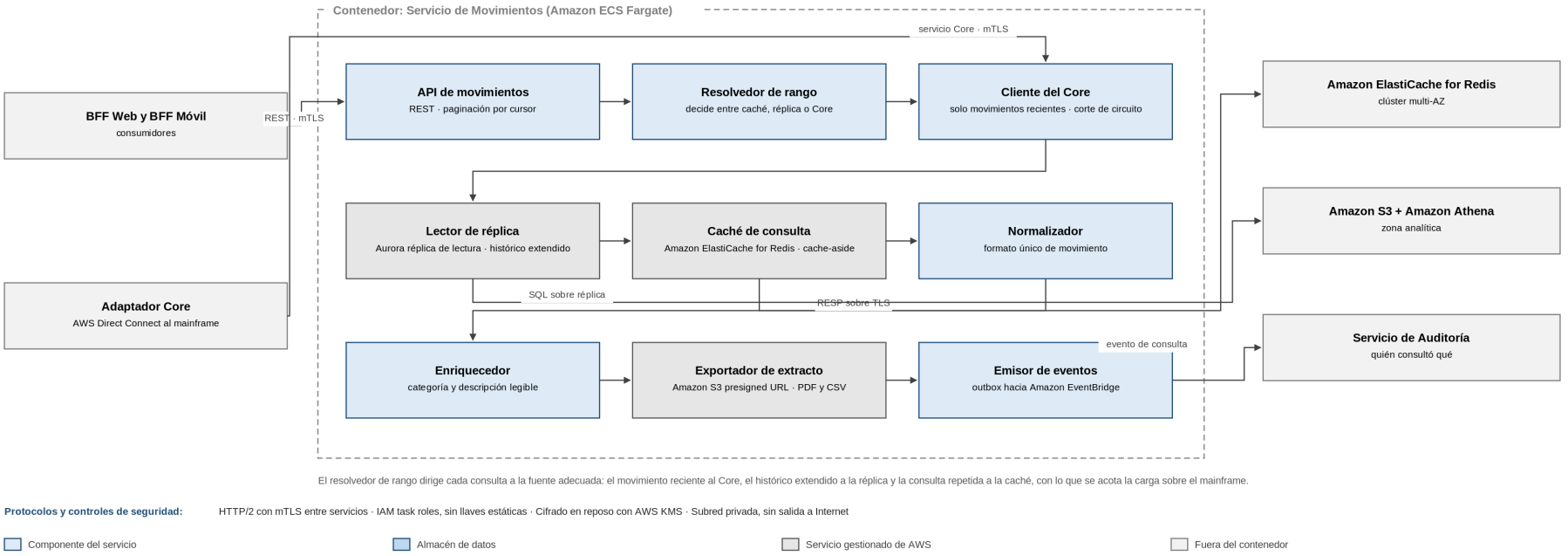


Figura 9. Nivel 3 - Componentes del Servicio de Movimientos

Nivel 3 - Componentes: Servicio de Transferencias

Transferencias propias e interbancarias · patrones: saga con compensación, idempotencia y outbox

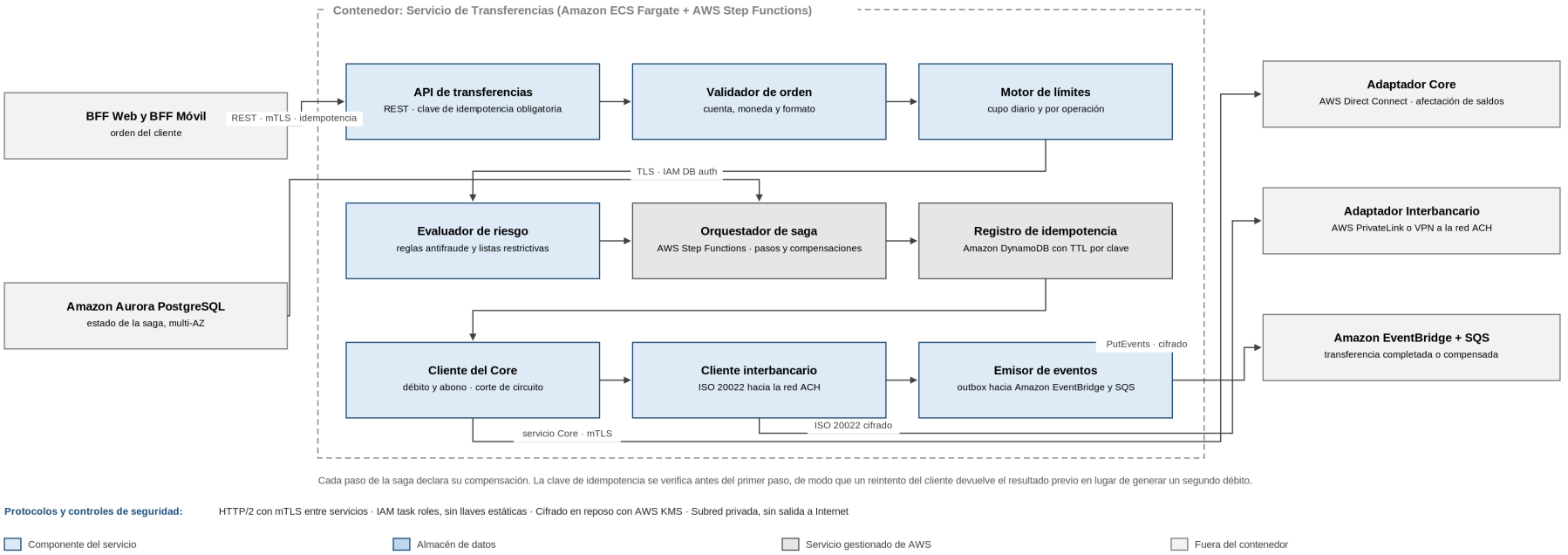


Figura 10. Nivel 3 - Componentes del Servicio de Transferencias

Nivel 3 - Componentes: Servicio de Notificaciones

Dos proveedores por exigencia normativa · patrones: corte de circuito, reintento y conciliación

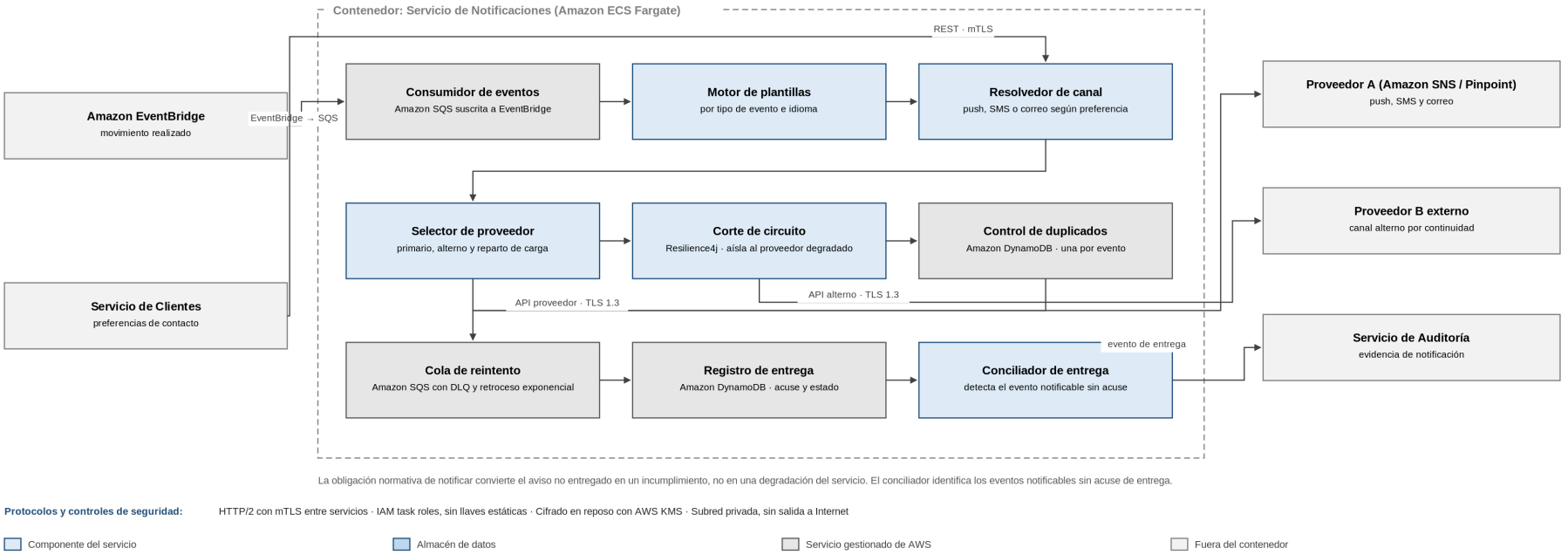


Figura 11. Nivel 3 - Componentes del Servicio de Notificaciones

Nivel 3 - Componentes: Servicio de Onboarding

Vinculación digital · patrones: máquina de estados, puertos y adaptadores y saga

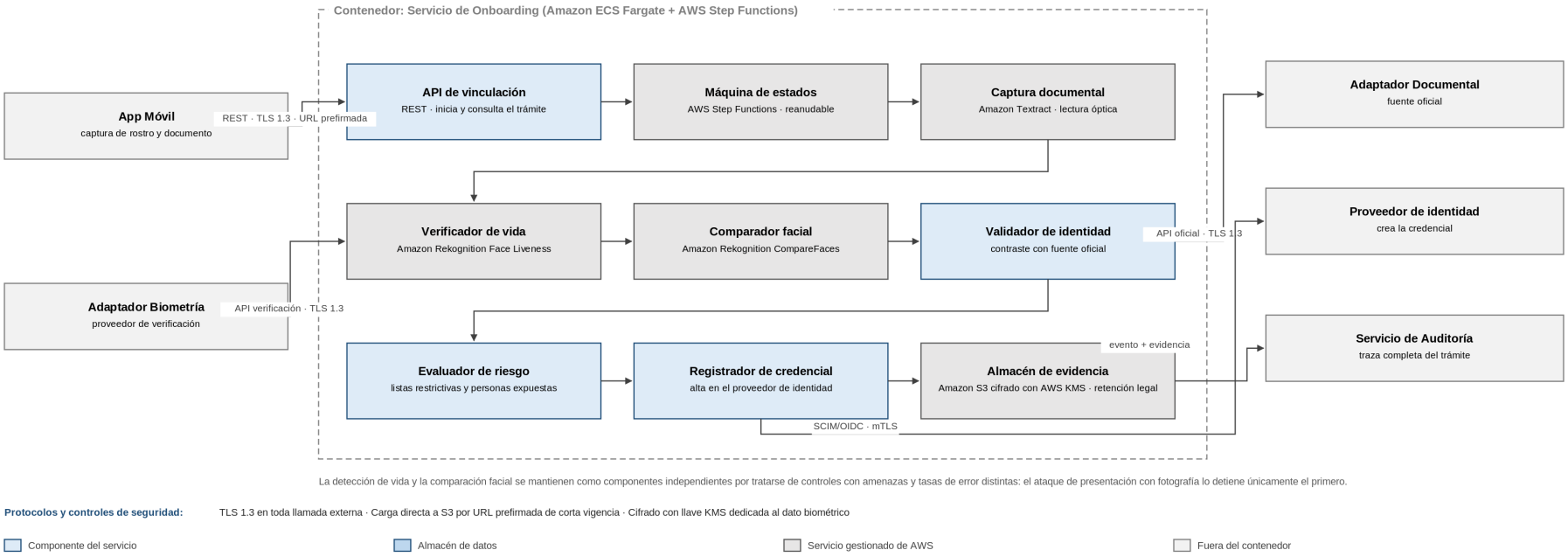


Figura 12. Nivel 3 - Componentes del Servicio de Onboarding

Nivel 3 - Componentes: Autenticación y autorización

Producto corporativo configurado más los controles propios del banco · patrón: autenticación adaptativa

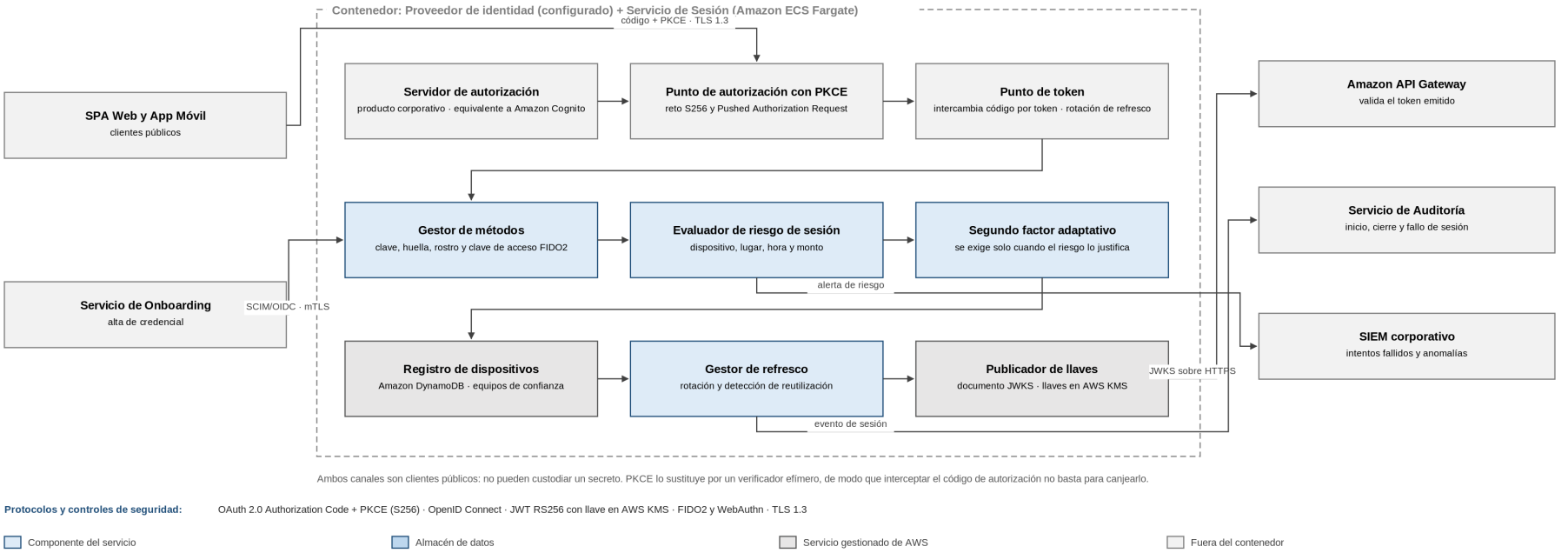


Figura 13. Nivel 3 - Componentes de Autenticación y autorización

Nivel 3 - Componentes: Servicio de Auditoría

Bitácora inmutable de todas las acciones · patrones: event sourcing, solo anexo y CQRS

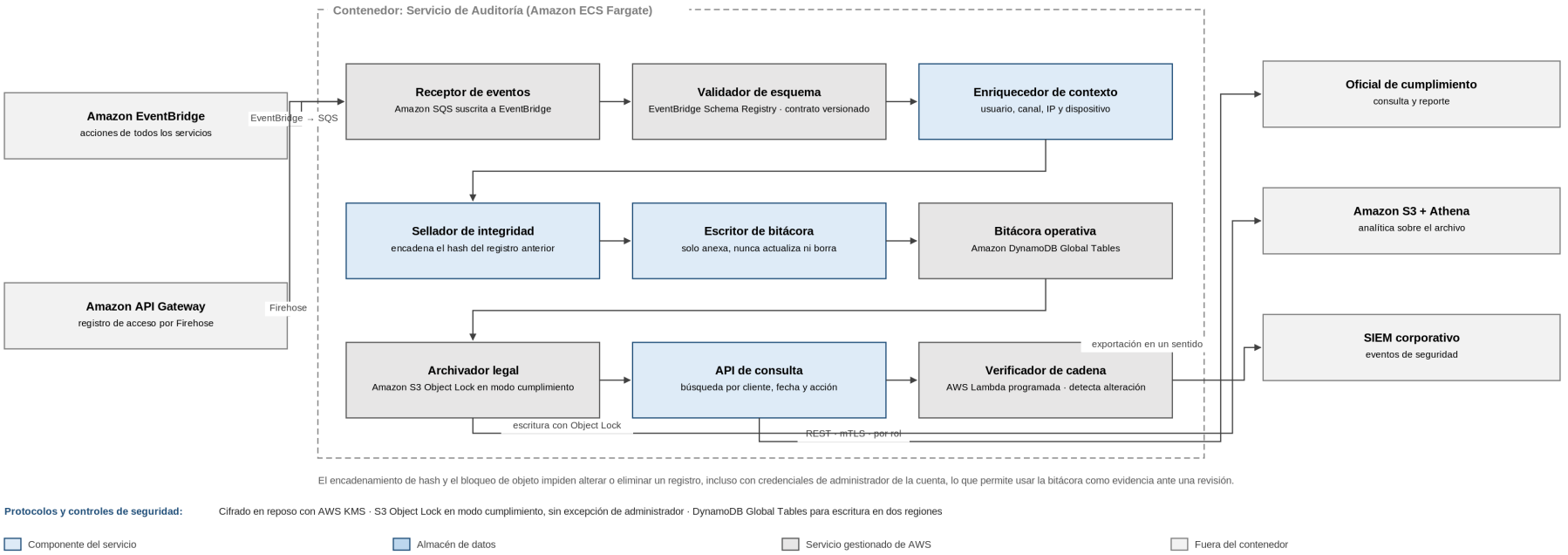


Figura 14. Nivel 3 - Componentes del Servicio de Auditoría

Nivel 3 - Componentes: Servicio de Perfil Frecuente

Persistencia del cliente recurrente · patrones: cache-aside, observador, vista materializada, estrategia y decorador

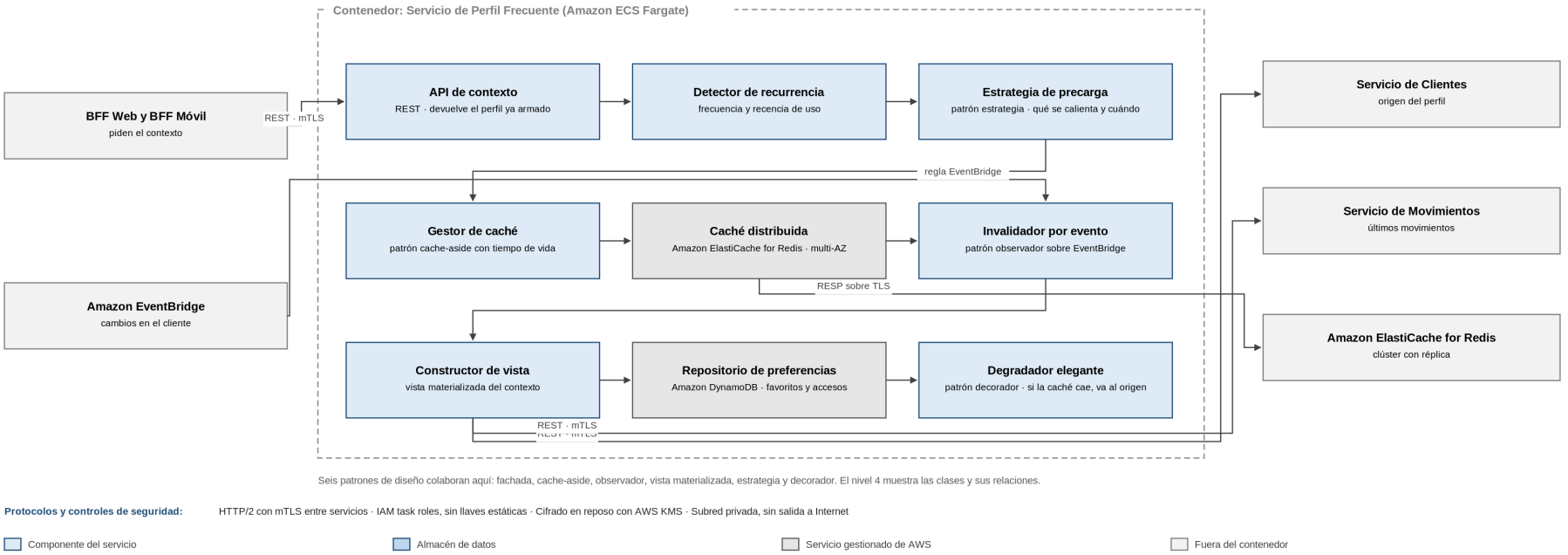


Figura 15. Nivel 3 - Componentes del Servicio de Perfil Frecuente

8. Nivel 4: diagramas de código

El ejercicio pide llegar hasta componentes. Se incluye además el nivel de código en los dos puntos donde la decisión de diseño admite varias soluciones y se documenta la adoptada: el orquestador de transferencias y el mecanismo de persistencia para clientes frecuentes, que el enunciado pide resolver con patrones de diseño.

En el resto de los componentes no se desciende a este nivel: el detalle de implementación cambia con cada iteración y su documentación quedaría desactualizada de inmediato.

Nivel 4 - Código: orquestador de saga de transferencias

Puertos y adaptadores, patrón saga con compensación, outbox e idempotencia

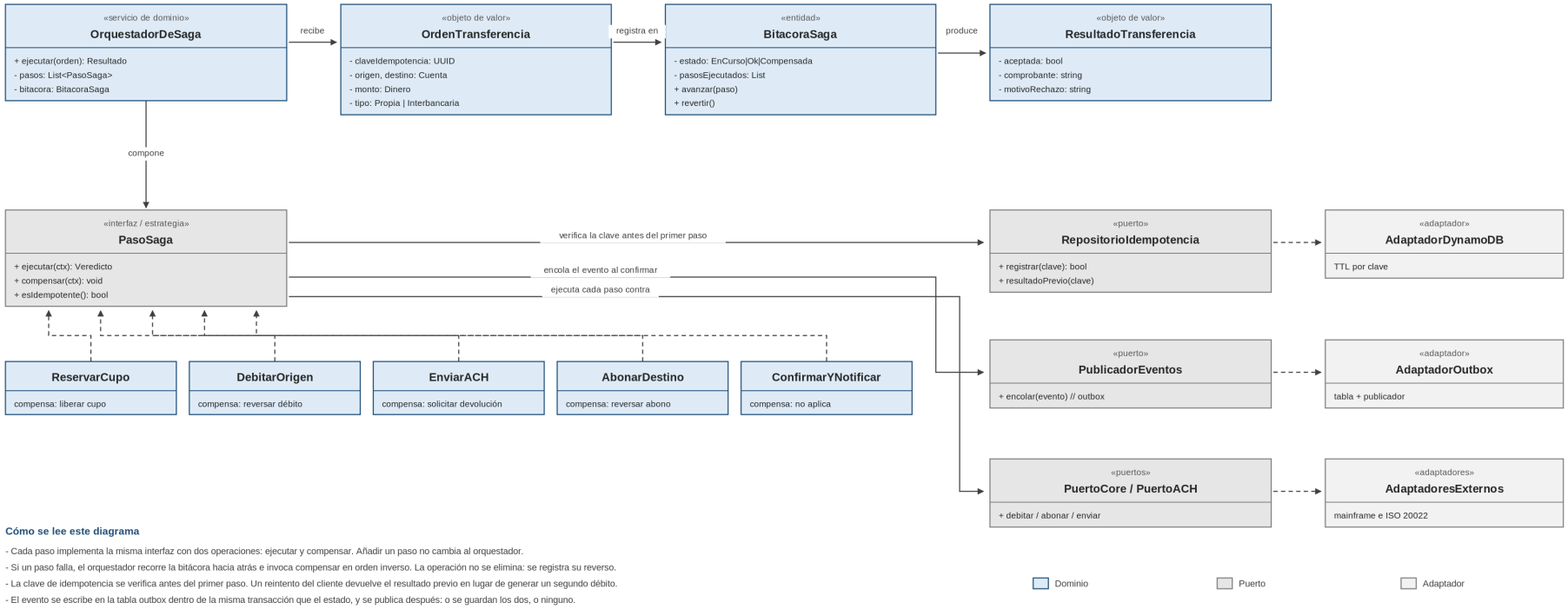
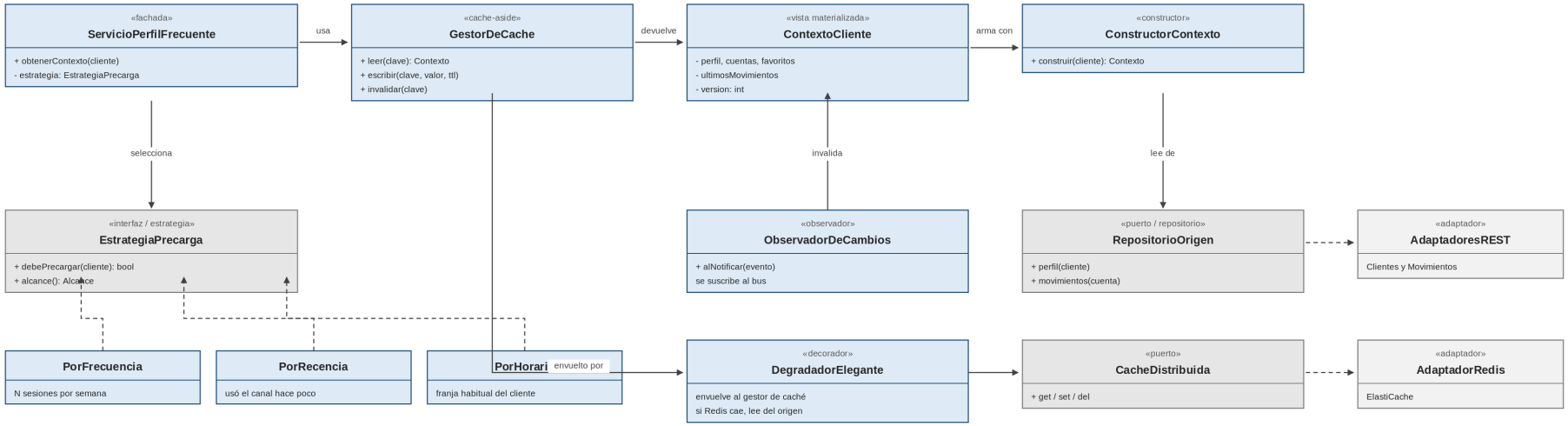


Figura 16. Nivel 4 - Código del orquestador de saga de transferencias

Nivel 4 - Código: contexto del cliente frecuente

Alternativa basada en patrones de diseño para la persistencia del cliente recurrente



Patrones aplicados y por qué

- Cache-aside: el servicio controla cuándo lee y cuándo escribe. Frente a read-through, no obliga a acoplar la caché al origen.
- Observador: la invalidación se dispara por evento del bus y no por tiempo de expiración, lo que reduce la ventana de dato desactualizado a segundos.
- Vista materializada: el contexto se arma una vez y se guarda completo, en lugar de recomponerlo en cada petición.
- Estrategia: la política de precarga es intercambiable; cambiarla no toca el servicio.
- Decorador: la degradación elegante envuelve al gestor de caché, así que la caída de Redis no deja al cliente sin servicio.
- Repositorio: el dominio pide perfil y movimientos sin saber que detrás hay dos servicios REST distintos.

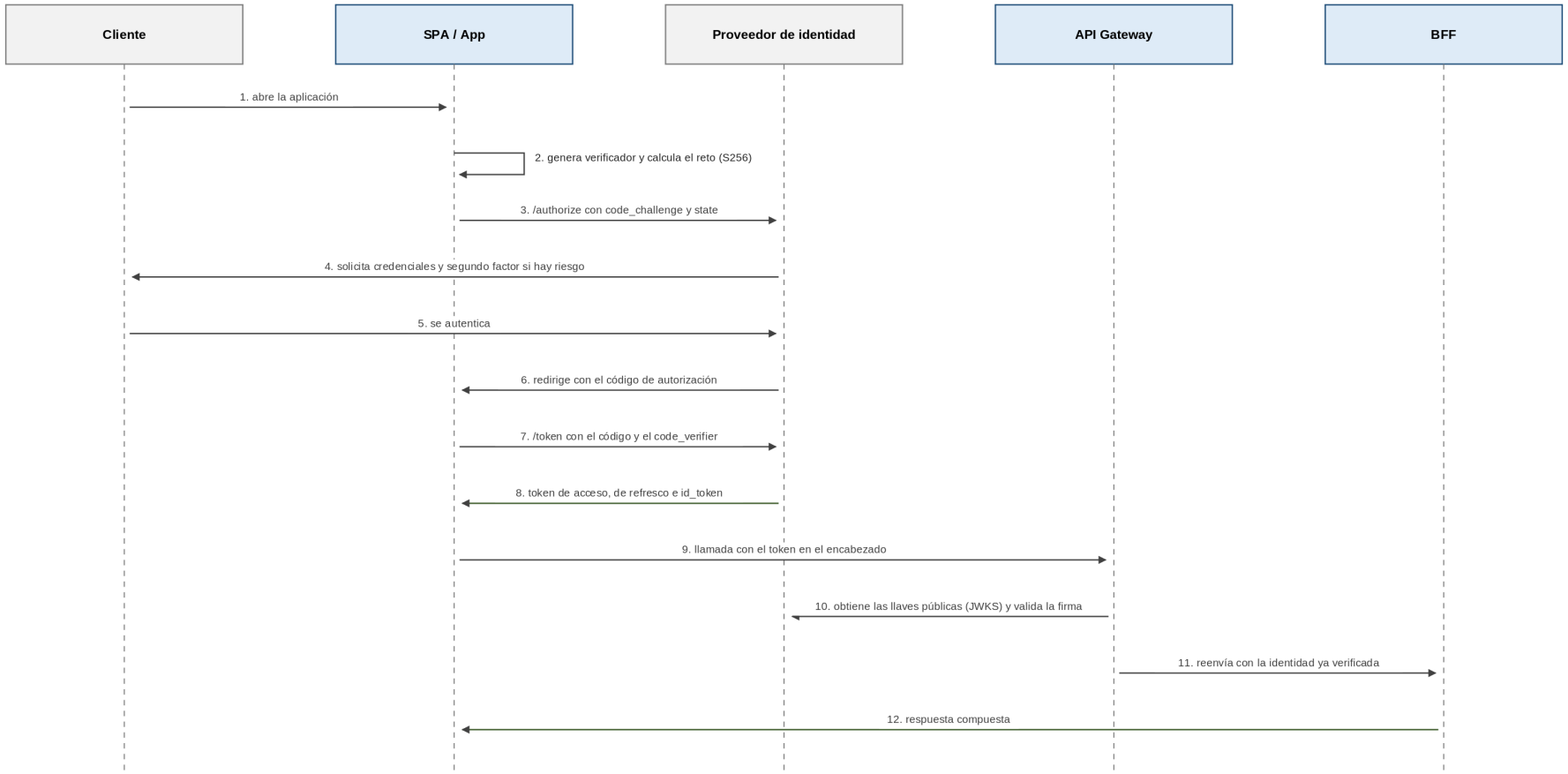
Figura 17. Nivel 4 - Código del contexto del cliente frecuente

9. Flujos principales

Tres secuencias muestran cómo colaboran los componentes en los caminos que concentran el riesgo del sistema.

Secuencia: autenticación con OAuth 2.0 (Authorization Code + PKCE)

Flujo recomendado para la SPA y la app móvil, que son clientes públicos

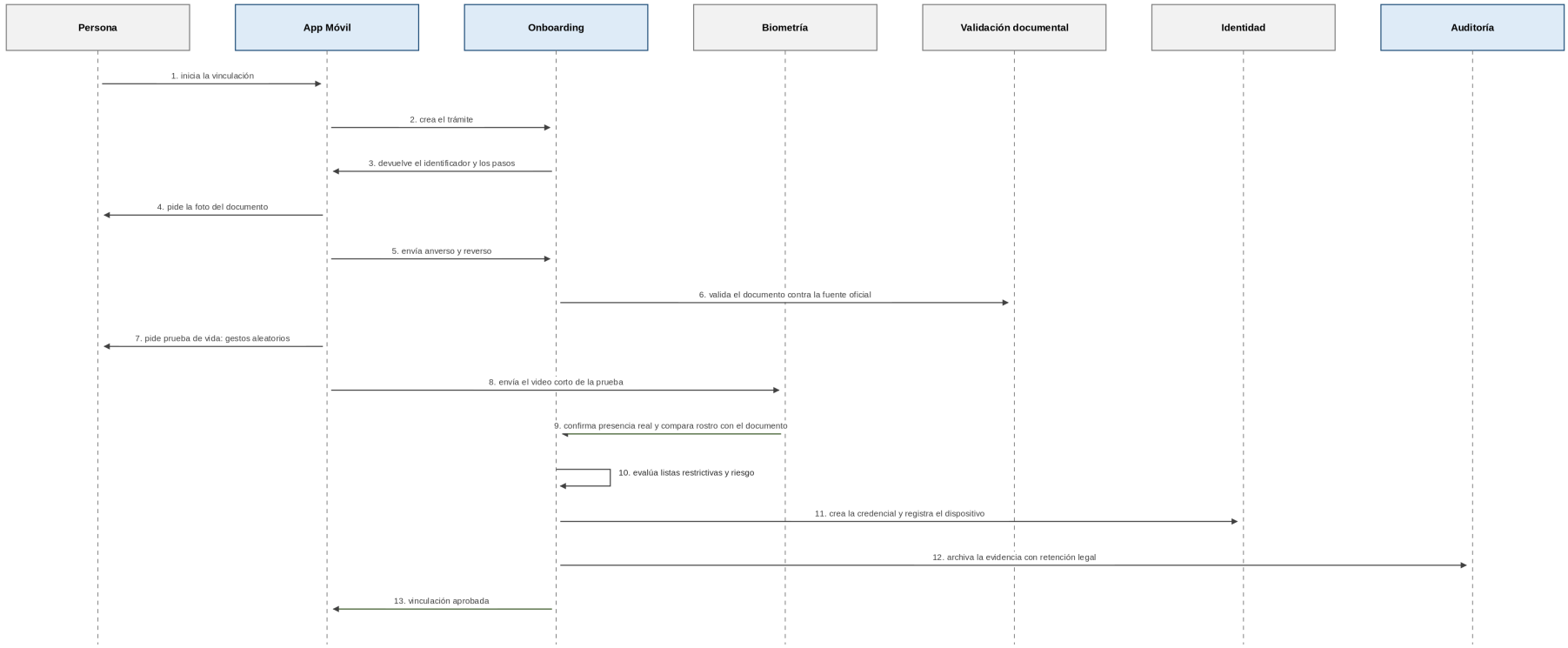


PKCE sustituye al secreto de cliente, que una SPA o una aplicación móvil no pueden custodiar. El parámetro state protege contra falsificación de petición entre sitios y el token de refresco rota en cada uso.

Figura 18. Secuencia - Autenticación con OAuth 2.0 (Authorization Code + PKCE)

Secuencia: vinculación digital con reconocimiento facial

Del primer ingreso en la app móvil hasta la credencial activa

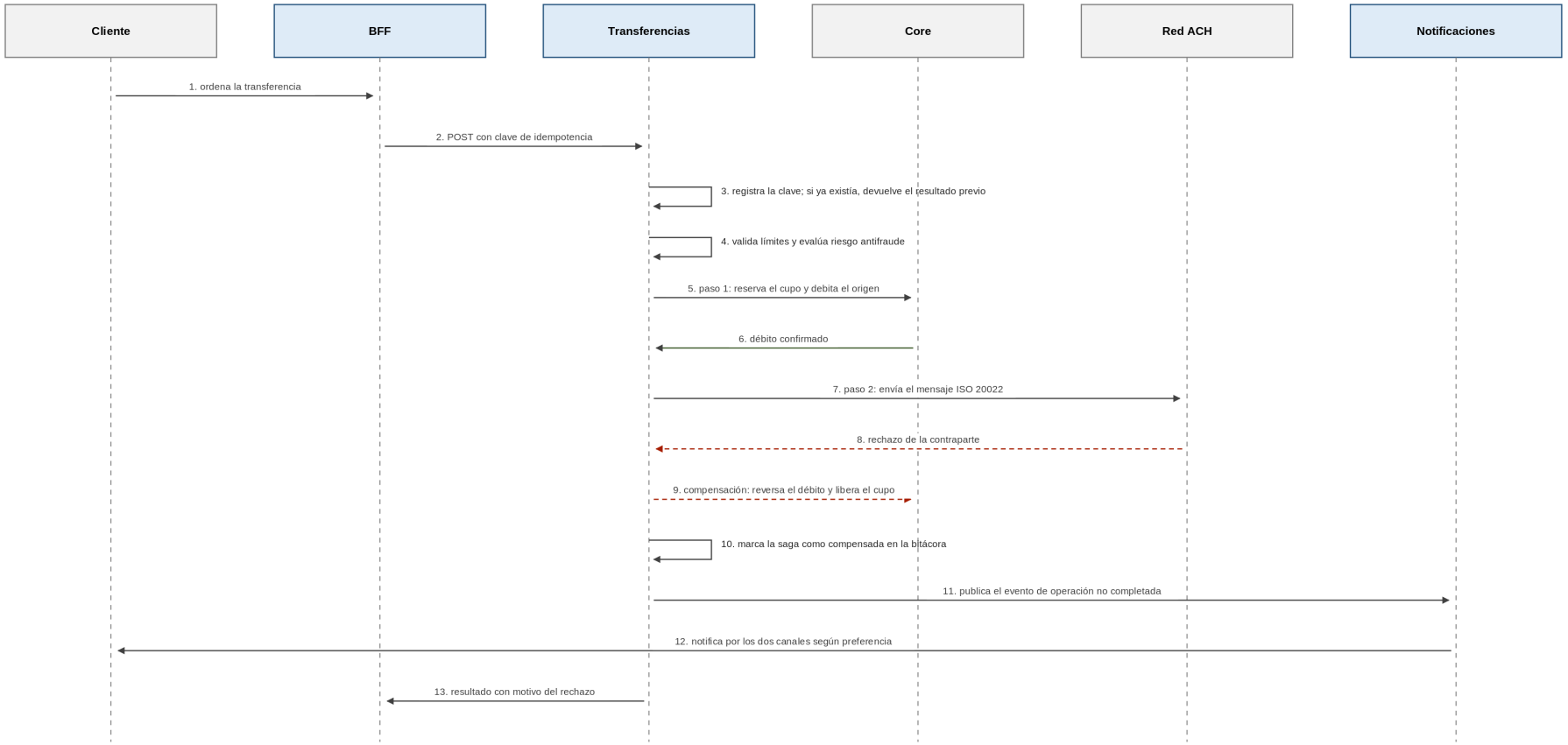


Si la prueba de vida falla, el trámite no se rechaza en silencio: pasa a revisión manual con la evidencia archivada. Rechazar sin rastro es lo que luego no se puede defender.

Figura 19. Secuencia - Vinculación digital con reconocimiento facial

Secuencia: transferencia interbancaria con saga y compensación

Camino feliz y camino de compensación cuando la red interbancaria rechaza



La compensación deja rastro: el débito no se elimina, se registra su reverso, de modo que la bitácora conserva tanto la operación como su corrección.

Figura 20. Secuencia - Transferencia interbancaria con compensación

10. Arquitectura de las aplicaciones de canal

10.1 SPA web: dos opciones evaluadas

Opción	A favor	En contra	Veredicto
Angular	Marco completo y opinado; TypeScript estricto; formularios reactivos tipados; ciclo de versiones predecible con actualización asistida.	Curva de entrada mayor; paquete inicial más pesado si no se divide por rutas.	**Elegida.** La banca en línea es, sobre todo, formularios con reglas y una vida útil larga.
React	Ecosistema enorme; compartiría lógica con React Native; comunidad amplia.	Cada equipo ensambla su propia arquitectura: enrutamiento, estado y formularios son decisiones separadas que divergen con el tiempo.	Alternativa válida si el equipo ya fuera de React.

Decisiones relevantes de la SPA: carga diferida por ruta para que el primer render no arrastre el módulo de transferencias; el token de acceso vive en memoria y nunca en almacenamiento local, con el refresco en cookie HttpOnly y SameSite estricto; y política de seguridad de contenido estricta, que es la defensa real contra el robo de token por inyección de script.

10.2 App móvil: dos opciones evaluadas

Opción	A favor	En contra	Veredicto
Flutter	Motor de render propio: la pantalla se comporta igual en iOS y Android. Compila a código nativo, arranque predecible. Acceso directo a biometría, almacén seguro y fijado de certificado.	Lenguaje propio (Dart); tamaño del binario algo mayor.	**Elegida.** La paridad de comportamiento entre plataformas es un requisito de riesgo en pantallas de transferencia.
React Native	Comparte lenguaje y parte de la lógica con la web; contratación más fácil.	El puente hacia el código nativo añade latencia justo donde más duele: listas largas de movimientos y animaciones. La paridad visual depende del componente nativo de cada sistema.	Alternativa si se priorizara compartir equipo con la web.

Controles propios del canal móvil: almacén seguro del sistema operativo para la credencial del dispositivo, con la clave privada dentro del enclave y sin posibilidad de exportarla; detección de equipo comprometido que bloquea la operación transaccional pero no la consulta; fijado de certificado contra interceptación; y biometría del dispositivo como desbloqueo local, nunca como sustituto de la autenticación en el servidor.

La huella y el rostro del dispositivo autorizan el uso de una credencial que ya está registrada; no son el factor de autenticación en sí. Confundir ambas cosas es el error habitual en banca móvil: si el dispositivo se compromete, la biometría local no protege nada en el servidor.

11. Arquitectura de autenticación y autorización

El enunciado indica que el servicio de autenticación ya existe como producto corporativo y solo requiere configuración, y pide **recomendar el mejor flujo según el estándar**.

11.1 Flujo recomendado y por qué

Para ambos canales se recomienda **Authorization Code con PKCE**, complementado con *Pushed Authorization Requests* y rotación del token de refresco con detección de reutilización.

Flujo	¿Aplica?	Razón
Authorization Code con PKCE	**Sí, recomendado**	La SPA y la app son clientes públicos: no pueden custodiar un secreto. PKCE lo sustituye por un verificador efímero que no viaja en la redirección, de modo que interceptar el código no basta para canjearlo.
Implicit	No	Devuelve el token en la URL, donde queda en historial, referer y registros del servidor. Está desaconsejado por las buenas prácticas de seguridad de OAuth 2.0 y eliminado en OAuth 2.1.
Resource Owner Password Credentials	No	Obliga a que la aplicación vea la contraseña del usuario, lo que impide el segundo factor y la federación. También queda fuera de OAuth 2.1.
Client Credentials	Solo entre servicios	No hay usuario final. Se usa para la comunicación máquina a máquina, no para el ingreso del cliente.
Device Authorization Grant	No	Resuelve otro problema: dispositivos sin teclado o sin navegador. No es el caso.

11.2 Métodos de ingreso después de la vinculación

Método	Cómo funciona	Nivel de garantía
Usuario y clave	Credencial conocida, con política de complejidad y bloqueo progresivo.	Base. Siempre acompañada de segundo factor en operación sensible.
Huella o rostro del dispositivo	Desbloquea localmente una credencial ligada al equipo, firmada en el enclave seguro.	Alto en el dispositivo registrado. No sustituye la verificación en el servidor.
Clave de acceso sin contraseña	Credencial FIDO2 resistente a suplantación, ligada al origen.	El más alto. Elimina el robo de credencial por engaño.
Segundo factor adaptativo	Se exige solo cuando el riesgo lo justifica: dispositivo nuevo, lugar inusual o monto alto.	Variable y proporcional al riesgo.

La biometría del dispositivo autoriza el uso de una credencial ya registrada; no es el factor de autenticación en sí mismo. Presentarla como tal es el error habitual: si el equipo se compromete, la biometría local no protege nada del lado del servidor.

11.3 Autorización, no solo autenticación

- El token lleva alcances por operación, no un permiso general. Consultar movimientos y ordenar transferencias son alcances distintos.
- La autorización a nivel de objeto se verifica en el servicio de dominio: que el token sea válido no significa que esa cuenta sea del titular. Es la vulnerabilidad número uno del Top 10 de seguridad de API.
- El token de acceso es de vida corta; el de refresco rota en cada uso y su reutilización revoca toda la familia, que es como se detecta un token robado.
- Las sesiones se pueden revocar de forma central, requisito para atender un reporte de fraude.

12. Arquitectura de integración con el onboarding

La vinculación digital es el punto donde convergen experiencia, seguridad y cumplimiento. Se diseña como un **trámite con estado**, no como una pantalla: puede interrumpirse y reanudarse, y cada paso deja evidencia.

12.1 Los pasos y qué garantiza cada uno

Paso	Control	Qué ataque previene
1. Captura del documento	Lectura óptica, verificación de elementos de seguridad y de coherencia interna.	Documento alterado o inventado.
2. Validación documental	Contraste contra fuente oficial.	Documento auténtico en apariencia pero inexistente o reportado.
3. Detección de vida	Prueba de presencia real con gestos aleatorios y análisis de la señal.	Ataque de presentación: fotografía, video grabado o máscara.
4. Comparación facial	Cotejo del rostro capturado contra el del documento, con umbral configurable.	Suplantación con documento ajeno.
5. Evaluación de riesgo	Listas restrictivas, personas expuestas y señales del dispositivo.	Vinculación de persona sancionada o de equipo asociado a fraude.
6. Alta de credencial	Registro en el proveedor de identidad y vínculo con el dispositivo.	Uso posterior de la identidad desde un equipo no reconocido.

La detección de vida y la comparación facial se mantienen como **componentes separados** a propósito: son controles con tasas de error independientes y con amenazas distintas. Fundirlos en un único paso impide ajustar uno sin degradar el otro, y deja al banco sin respuesta ante el ataque de inyección de video, que no es un problema de comparación sino de presencia.

12.2 Decisiones de integración

Decisión	Motivo
La verificación la hace el servidor, nunca la aplicación.	Una decisión tomada en el dispositivo es manipulable. La app captura y transmite; no concluye.
El proveedor de biometría entra por un adaptador.	Cambiar de proveedor debe ser sustituir un componente, no rehacer el trámite.
El trámite es una máquina de estados persistida.	La vinculación se interrumpe con frecuencia por red o por batería; obligar a empezar de cero destruye la conversión.
Un rechazo no es silencioso: pasa a revisión manual con su evidencia.	Un rechazo sin rastro impide atender un reclamo posterior y responder ante el supervisor.
La evidencia biométrica se cifra con llave dedicada y retención acotada.	Es dato personal de categoría especial: merece resguardo reforzado y no debe conservarse más de lo necesario.

13. Diseño de la solución de auditoría

El enunciado pide una base de datos de auditoría que registre **todas** las acciones del cliente. El reto no es guardar: es poder demostrar después que nada se alteró.

13.1 Qué se registra

Categoría	Ejemplos	Retención sugerida
Autenticación	Ingreso, cierre, intento fallido, cambio de método, alta de dispositivo.	Plurianual según norma local.
Consulta	Saldos, movimientos, descarga de extracto, datos del perfil.	Plurianual.
Transacción	Orden, aprobación, rechazo, compensación, confirmación.	La más larga; es la base de un eventual litigio.
Vinculación	Cada paso del trámite, su resultado y la evidencia asociada.	Según norma de conocimiento del cliente.
Administración	Cambio de límites, bloqueo, desbloqueo, acción del personal del banco.	Plurianual.
Seguridad	Alerta, bloqueo automático, detección de anomalía.	Según política de seguridad.

13.2 Cómo se garantiza que no se pueda alterar

Mecanismo	Qué impide
Escritura de solo anexo: nunca se actualiza ni se borra un registro.	La corrección silenciosa de un hecho ya ocurrido.
Hash encadenado: cada registro incorpora el hash del anterior.	La alteración retroactiva: romper un eslabón deja detectable toda la cadena posterior.
Bloqueo de objeto en modo cumplimiento sobre el archivo.	El borrado o la sobrescritura, incluso con credenciales de administrador de la cuenta.
Separación entre bitácora operativa y archivo legal.	Que la consulta frecuente y la conservación plurianual compitan por el mismo recurso y el mismo costo.
Verificador de cadena con ejecución programada.	Que una alteración pase inadvertida hasta la auditoría anual.
Escritura en dos regiones mediante tablas globales.	La pérdida de evidencia ante la caída de una región.

13.3 Cómo llega el evento a la bitácora

Los servicios no escriben directo en la bitácora: publican un evento mediante el patrón **outbox**, dentro de la misma transacción que el cambio de estado. El Servicio de Auditoría lo consume, valida su esquema, lo enriquece con contexto y lo sella. Así, o se guardan el hecho y su registro, o no se guarda ninguno de los dos. Escribir la bitácora con una llamada síncrona aparte es cómo aparecen operaciones sin rastro cuando esa llamada falla.

14. Arquitectura de acceso a datos

El caso declara dos fuentes de información del cliente: el Core, con el dato básico, los productos y los movimientos, y un sistema complementario con el detalle. La arquitectura no las expone tal como están: las unifica detrás de un servicio de dominio.

Necesidad	Dónde se resuelve	Motor y patrón
Dato básico del cliente y productos	Servicio de Clientes, vía adaptador del Core.	Capa anticorrupción. El modelo del mainframe no se filtra al dominio.
Detalle ampliado del cliente	Servicio de Clientes, vía adaptador del complementario.	Fusionador de perfil con regla explícita de precedencia por campo.
Movimientos recientes	Servicio de Movimientos, consulta en línea al Core.	Resolvedor de rango: solo lo reciente llega al mainframe.
Movimientos históricos	Réplica de lectura y zona analítica.	Lectura separada de la escritura; el Core no soporta carga analítica.
Contexto del cliente recurrente	Servicio de Perfil Frecuente.	Cache-aside, vista materializada e invalidación por evento.
Datos propios de la banca digital	Aurora PostgreSQL por servicio.	Base de datos por servicio; el acceso entre servicios es solo por interfaz publicada.
Bitácora de acciones	DynamoDB con archivo en S3.	Solo anexa, hash encadenado y bloqueo de objeto.

14.1 Reglas de acceso que se aplican sin excepción

- Ningún servicio accede a la base de datos de otro: solo a través de su interfaz publicada. Es lo que permite desplegarlos por separado.
- Toda consulta al Core pasa por el adaptador, nunca directa. Si el mainframe cambia su contrato, cambia un componente.
- La lectura intensiva va a réplica o a caché. El escritor se reserva para la operación transaccional.
- El dato personal se minimiza en cada salto: el BFF recorta campos antes de responder al canal, y los registros nunca llevan dato sensible en claro.
- Toda lectura de dato de cliente queda registrada en la bitácora con quién, cuándo, desde dónde y qué consultó.

15. Integración con servicios externos

Servicio externo	Estilo de integración	Controles aplicados
Core Bancario	Servicios en línea a través del adaptador, con capa anticorrupción.	Mamparo de conexiones dedicado, corte de circuito, tiempo de espera agresivo y caché para lo repetido. El Core es el recurso menos elástico: se protege de nosotros mismos.
Sistema Complementario	Servicio interno o réplica, según lo que exponga.	Degradación elegante: si no responde, se entrega el perfil básico marcado como parcial en lugar de fallar la pantalla completa.
Red interbancaria / ACH	Mensajería ISO 20022 a través del adaptador interbancario.	Idempotencia por referencia de operación, conciliación diaria de lo enviado contra lo liquidado y compensación ante rechazo.
Proveedores de notificaciones A y B	API del proveedor, con cola intermedia y acuse.	Corte de circuito por proveedor, conmutación automática, control de duplicados y conciliación de entrega.
Verificación de identidad	API del proveedor a través del adaptador de biometría.	Umbrales configurables por el banco, evidencia almacenada del lado del banco y camino de revisión manual.
Validación documental	API de la fuente oficial.	Reintento acotado y respuesta en diferido si la fuente no está disponible; el trámite espera, no se cae.
Proveedor de identidad	OpenID Connect con descubrimiento y llaves públicas.	Validación local de la firma con las llaves en caché, para no depender del emisor en cada petición.
SIEM corporativo	Exportación de eventos de seguridad.	Canal unidireccional: el SIEM recibe, nunca consulta hacia adentro.

Regla común a todas las integraciones externas: **ninguna llamada saliente carece de tiempo de espera, de reintento acotado y de corte de circuito**. Un tercero lento, no uno caído, es lo que agota los hilos y tumba la plataforma entera.

16. Vista de despliegue, alta disponibilidad y recuperación

16.1 Alta disponibilidad y tolerancia a fallos

Nivel	Mecanismo	Fallo que tolera
Borde	CloudFront, WAF y Shield distribuidos globalmente; Route 53 con verificación de salud.	Saturación, denegación de servicio y caída de un punto de presencia.
Cómputo	Tareas de ECS repartidas en tres zonas, detrás de balanceo, con reemplazo automático.	Pérdida de una tarea o de una zona completa.
Datos relacionales	Aurora con escritor y réplicas en zonas distintas, conmutación automática.	Caída del escritor, sin pérdida de dato confirmado.
Datos de clave y valor	DynamoDB replicado por diseño, con tablas globales.	Caída de zona y de región.
Caché	Clúster de Redis con réplica y conmutación.	Pérdida de un nodo; además el sistema degrada al origen.
Mensajería	Colas gestionadas con redundancia y cola de descarte.	Indisponibilidad temporal del consumidor.
Dependencias externas	Corte de circuito, mamparo, reintento y segundo proveedor donde lo hay.	Degradación o caída de un tercero.

16.2 Recuperación ante desastres

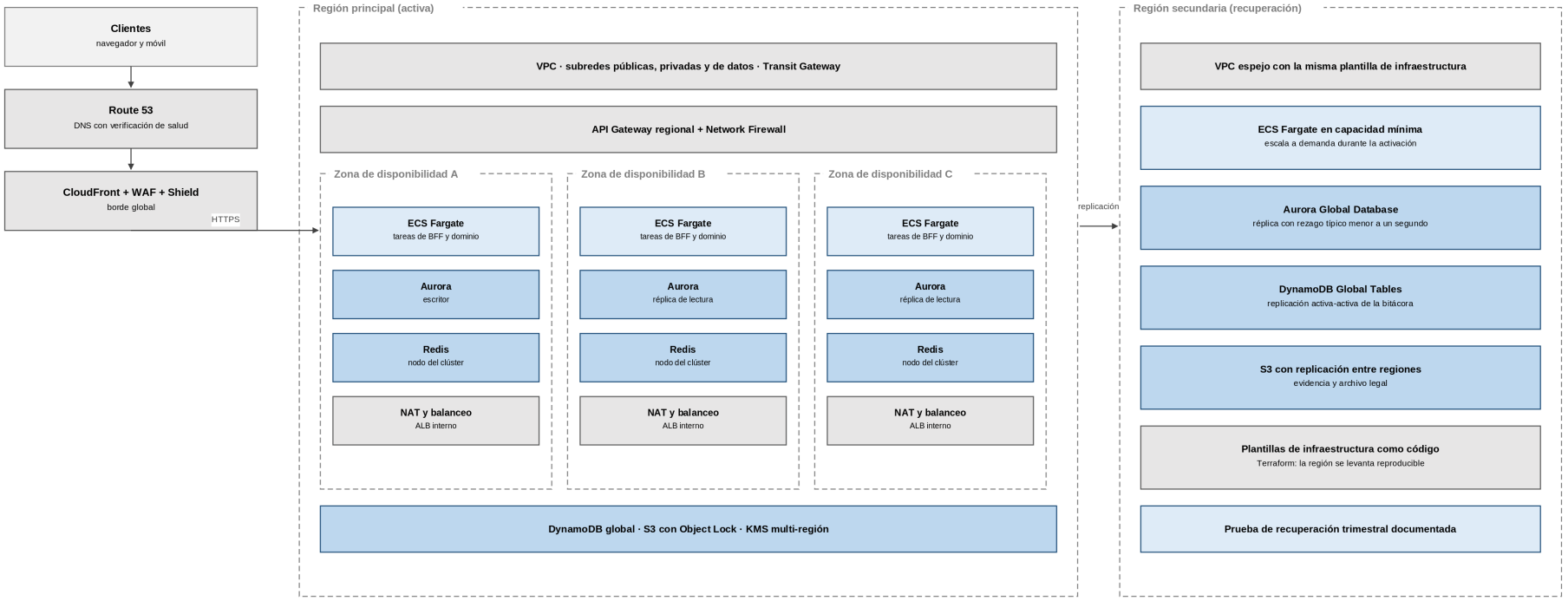
Región principal activa y región secundaria en capacidad mínima con los datos ya replicados. La infraestructura está declarada como código, de modo que la segunda región se levanta de forma reproducible. El plan de recuperación se ejercita cada trimestre y el resultado se documenta, con el tiempo real de restablecimiento medido y comparado contra el objetivo comprometido.

16.3 Baja latencia

- Contenido estático y respuestas cacheables servidos desde el borde, cerca del cliente.
- Región principal elegida por cercanía geográfica a la base de clientes.
- Lectura dirigida a réplicas y a caché; el escritor queda libre para la operación transaccional.
- Perfil del cliente frecuente precargado, de modo que la pantalla de inicio no espera al Core.
- Carga útil reducida en el canal móvil y una sola llamada por pantalla.
- Conexiones persistentes y agrupadas hacia el Core, que es donde más cuesta cada apertura.

Vista de despliegue sobre AWS

Alta disponibilidad multi-AZ en la región principal y recuperación en una segunda región



Objetivos de nivel de servicio por componente

Servicio	Disponibilidad	RTO	RPO	Mecanismo
Consulta de saldos y movimientos	99,95 %	15 min	0	Multi-AZ activo-activo
Transferencias y pagos	99,95 %	15 min	0	Multi-AZ, escritor con conmutación automática
Vinculación digital	99,5 %	2 h	15 min	Reintentable: el trámite se reanuda
Notificaciones	99,9 %	1 h	0	Dos proveedores y cola persistente
Auditoría	99,99 %	15 min	0	Tablas globales, escritura en dos regiones
Analítica y reportes	99,0 %	8 h	24 h	Reprocesable desde el origen

A construir · Datos · Servicio gestionado · Externo

Figura 21. Vista de despliegue sobre AWS con objetivos de nivel de servicio

17. Catálogo de servicios de AWS utilizados

La justificación alcanza también a la elección de **tecnologías**, no solo de patrones. Cada servicio se presenta con **dos razones** y con la alternativa que se descartó, de modo que la elección quede atada a un problema concreto del caso.

17.1 Cómputo y contenedores

Servicio	Por qué este (dos razones)	Alternativa descartada
Amazon ECS con AWS Fargate	**1.** Ejecuta contenedores sin administrar servidores ni parcharlos, lo que reduce la superficie que el banco debe asegurar y auditar. **2.** Conserva la portabilidad: el artefacto es una imagen estándar, de modo que la dependencia del proveedor no es irreversible.	Amazon EKS: más potente, pero añade la operación de Kubernetes que este tamaño de equipo no justifica. AWS Lambda: arranque en frío y costo mayor en carga sostenida.
AWS Lambda	**1.** Ejecuta trabajos de segundos (verificación de la cadena de auditoría, tareas programadas) sin mantener capacidad encendida. **2.** Escala a cero: el costo de estas funciones es proporcional a su uso real, que es intermitente por naturaleza.	Tarea programada en ECS: mantendría capacidad reservada para una ejecución de segundos.
AWS Step Functions	**1.** Persiste el estado de la saga y de la vinculación fuera del proceso, de modo que un reinicio no pierde el trámite en curso. **2.** Expresa compensación, reintento y tiempo de espera de forma declarativa y auditable, en lugar de repartirlos por el código.	Orquestación en código propio: obliga a reimplementar persistencia de estado, reintento y compensación, y a probarlos.
Application Load Balancer	**1.** Enruta por ruta y verifica salud en capa de aplicación, que es lo que permite retirar una tarea enferma sin afectar al usuario. **2.** Se integra de forma nativa con el registro de servicios de ECS, así que el escalado no exige reconfigurar nada.	Network Load Balancer: no aporta en tráfico HTTP con enrutamiento por ruta y no verifica salud a nivel de aplicación.

17.2 Datos y almacenamiento

Servicio	Por qué este (dos razones)	Alternativa descartada
Amazon Aurora PostgreSQL	**1.** Ofrece transacciones y restricciones de integridad, que son irrenunciables en saldos y en órdenes de transferencia. **2.** Conmuta de escritor en menos de un minuto y replica a varias zonas sin pérdida de dato confirmado.	Amazon RDS estándar: menor costo pero conmutación más lenta y réplicas menos eficientes. NoSQL: no da las garantías transaccionales que el dinero exige.
Amazon Aurora Global Database	**1.** Replica a la segunda región con rezago típico menor a un segundo, lo que hace realista un punto de recuperación cercano a cero. **2.** Permite promover la región secundaria en minutos, frente a las horas que toma restaurar desde respaldo.	Respaldo y restauración entre regiones: tiempo de recuperación de horas, incompatible con el objetivo comprometido.
Amazon DynamoDB	**1.** La escritura intensiva de clave conocida (idempotencia, duplicados, bitácora) escala sin ventanas de mantenimiento ni ajuste de índices. **2.** El tiempo de vida por elemento caduca solo los registros temporales, como las claves de idempotencia, sin proceso de limpieza propio.	PostgreSQL para el mismo uso: funcionaría, pero la tabla crece sin control y el mantenimiento compite con la carga transaccional.

Servicio	Por qué este (dos razones)	Alternativa descartada
DynamoDB Global Tables	**1.** Escribe la bitácora de auditoría en dos regiones de forma activa, así que la evidencia nunca existe en un solo lugar. **2.** Resuelve la replicación sin proceso propio que mantener ni ventana en la que el dato esté desprotegido.	Replicación por lote: deja una ventana en la que la evidencia solo está en una región.
Amazon ElastiCache for Redis	**1.** Caché compartida entre instancias: cualquier tarea responde igual, lo que es condición para el escalado horizontal y el reemplazo automático. **2.** Latencia de milisegundo bajo, que es lo que hace viable precargar el contexto del cliente frecuente sin esperar al Core.	Caché en memoria del proceso: rompe el escalado horizontal y se pierde en cada reemplazo de tarea.
Amazon S3	**1.** Durabilidad muy alta y costo por gigabyte bajo, que es lo que hace sostenible una retención legal de varios años. **2.** Ciclo de vida automático por antigüedad: el dato frío baja de nivel sin intervención ni proceso propio.	Almacenamiento en bloque: más caro, sin ciclo de vida y sin bloqueo de objeto.
Amazon S3 Object Lock	**1.** En modo cumplimiento, ni el administrador de la cuenta puede borrar ni sobrescribir el objeto durante el plazo de retención. **2.** Es un control reconocible por un auditor, no una promesa de proceso interno: se puede demostrar con la configuración.	Permisos restrictivos: un administrador podría modificarlos, que es justo el riesgo que hay que eliminar.
Amazon Athena	**1.** Consulta el archivo donde está, sin mover ni duplicar datos sensibles hacia otro almacén. **2.** Cobra por consulta ejecutada, lo que encaja con un uso eventual de cumplimiento y no con una carga continua.	Amazon Redshift: capacidad encendida de forma permanente, desproporcionada para una consulta eventual.

17.3 Integración y mensajería

Servicio	Por qué este (dos razones)	Alternativa descartada
Amazon API Gateway	**1.** Resuelve en configuración lo que de otro modo cada servicio reimplementaría: validación de token, cuotas, planes de uso y registro de acceso. **2.** Permite despliegue canario por etapa y por ruta, que es cómo se reduce el radio de impacto de un cambio en un canal que opera todo el día.	Balanceador con autenticación propia: obliga a construir y mantener cuotas, planes y canario.
Amazon EventBridge	**1.** Filtra por contenido del evento, de modo que agregar un consumidor nuevo es agregar una regla y no tocar al productor. **2.** El registro de esquemas versiona el contrato del evento, que es lo que evita que un cambio del productor rompa a sus consumidores en silencio.	Amazon SNS: entrega a suscriptores pero sin filtrado por contenido ni contrato de esquema.
Amazon SQS con cola de descarte	**1.** Garantiza que el trabajo diferido sobreviva al reinicio del consumidor, lo que es condición para no perder una notificación obligatoria. **2.** Aísla en una cola aparte lo que falla de forma repetida, para que un mensaje defectuoso no bloquee el avance de los demás.	Reintento en memoria del proceso: pierde el mensaje cuando la tarea se recrea.
Amazon SNS y Amazon Pinpoint	**1.** Cubre push, SMS y correo con una sola integración, lo que simplifica el proveedor principal del canal de notificación. **2.** Entrega acuse de recibo, que es el insumo que necesita el conciliador para detectar lo no notificado.	Proveedor externo único: concentraría en un tercero una obligación normativa del banco.

Servicio	Por qué este (dos razones)	Alternativa descartada
AWS PrivateLink y VPC Link	**1.** El tráfico entre el gateway y los servicios no sale a Internet en ningún momento, ni siquiera cifrado. **2.** Elimina la necesidad de exponer una dirección pública con lista de permitidos, que es superficie de ataque evitable.	Exposición pública restringida por dirección IP: más superficie y más configuración que mantener.
AWS Direct Connect	**1.** Latencia estable y predecible hacia el Core, que está en el camino crítico de cada consulta de saldo y de cada transferencia. **2.** Ancho de banda dedicado: el tráfico del canal digital no compite con el resto del tráfico corporativo del banco.	VPN sobre Internet: variabilidad de latencia inaceptable en el camino transaccional.

17.4 Identidad, seguridad y cumplimiento

Servicio	Por qué este (dos razones)	Alternativa descartada
AWS IAM con roles de tarea	**1.** Elimina las llaves estáticas: no hay secreto que filtrar en la imagen, en una variable de entorno ni en el repositorio. **2.** La credencial es temporal y rota sola, así que una filtración puntual caduca por sí misma en minutos.	Credenciales en variables de entorno: el hallazgo de auditoría más común y más evitable.
AWS KMS	**1.** Permite una llave dedicada por dominio de dato, de modo que el acceso al dato biométrico se controla por separado del resto. **2.** Registra cada uso de cada llave, lo que convierte el cifrado en evidencia auditable y no solo en una propiedad técnica.	Cifrado gestionado por el servicio: no separa llaves por sensibilidad ni permite auditar su uso.
AWS Secrets Manager	**1.** Rota las credenciales de terceros de forma automática, que es lo que convierte una política escrita en un control real. **2.** Integra la rotación con las bases de datos, así que el cambio de contraseña no exige una ventana de mantenimiento.	Parameter Store: válido para configuración, pero sin rotación gestionada.
AWS WAF y AWS Shield Advanced	**1.** Aplica el conjunto gestionado de reglas contra OWASP Top 10, que se actualiza sin trabajo del equipo. **2.** Cubre el ataque volumétrico con respuesta del proveedor, que una entidad financiera no puede absorber por sí sola.	Reglas propias en el balanceador: sin conjunto gestionado ni respuesta ante ataques volumétricos.
Amazon Rekognition Face Liveness y CompareFaces	**1.** La detección de vida se mantiene actualizada frente a ataques de presentación que evolucionan cada mes; no es el negocio del banco perseguirlos. **2.** Son dos operaciones separadas, lo que permite ajustar el umbral de una sin degradar la otra y cambiar una sola si hace falta.	Modelo propio: exige investigación continua. Suite cerrada: funde los controles y quita el ajuste de umbrales.
Amazon Textract	**1.** Extrae campos estructurados del documento de identidad, no solo texto suelto, lo que reduce el error de captura manual. **2.** Es un problema resuelto y commodity: construirlo no diferencia al banco y sí añade mantenimiento permanente.	Motor de reconocimiento propio: alto mantenimiento para un problema ya resuelto.
Amazon GuardDuty y AWS Security Hub	**1.** Detectan comportamiento anómalo sin que el equipo tenga que escribir y mantener las reglas de correlación. **2.** Exportan al SIEM corporativo en formato normalizado, de modo que se suman a la vigilancia del banco en lugar de competir con ella.	Solo registros: detecta tarde y obliga a construir toda la correlación.

Servicio	Por qué este (dos razones)	Alternativa descartada
Amazon Cognito	**1.** Se menciona únicamente como equivalente del producto corporativo de identidad, que el enunciado indica que ya existe y solo se configura. **2.** Sirve de referencia concreta de las capacidades esperadas del producto: PKCE, PAR, rotación de refresco y publicación de JWKS.	No se propone reemplazar el producto corporativo: el enunciado lo excluye del alcance.

17.5 Observabilidad y operación

Servicio	Por qué este (dos razones)	Alternativa descartada
Amazon CloudWatch	**1.** Integra métricas y registros de los servicios gestionados sin desplegar agentes, que es menos software que asegurar en un entorno regulado. **2.** Mantiene el dato de telemetría dentro de la cuenta del banco, lo que evita un análisis de privacidad sobre un tercero que ve tráfico.	Herramienta externa unificada: mejor experiencia, pero añade un tercero con acceso a datos de operación.
Amazon CloudWatch RUM	**1.** Mide la experiencia real en la red del cliente, que es donde ocurre la latencia que el usuario percibe. **2.** Correlaciona el error del navegador con la traza del servidor, lo que acorta el diagnóstico de un problema reportado.	Solo medición sintética: no refleja la red ni el dispositivo real del cliente.
AWS X-Ray	**1.** Reconstruye la cadena completa de una petición a través de gateway, BFF, servicios y eventos. **2.** Permite ubicar el tramo lento de una transferencia, que con registros correlacionados a mano cuesta horas.	Registros correlacionados manualmente: no reconstruyen la cadena ni miden cada tramo.
Amazon Route 53	**1.** Verifica salud y conmuta entre regiones sin intervención, que es lo que hace real el tiempo de recuperación comprometido. **2.** Permite enrutar por latencia, acercando a cada cliente a la región que mejor le responde.	DNS estático: la conmutación dependería de una persona disponible en el momento del incidente.
AWS CloudTrail	**1.** Registra toda acción administrativa sobre la infraestructura, incluida la del propio equipo de operación. **2.** Es requisito directo de los marcos de cumplimiento aplicables; no tiene sustituto razonable.	No aplica: es un control exigido, no una opción entre varias.
Terraform	**1.** Hace reproducible la segunda región: se levanta con la misma plantilla y no a mano bajo presión. **2.** Conserva la portabilidad del diseño hacia otro proveedor, que es la contrapartida de haber elegido una nube concreta.	CloudFormation: válido y nativo, pero ata la definición de infraestructura al proveedor.

18. Vista de seguridad

El modelo es de defensa en profundidad: cuatro zonas de confianza en las que cada una solo acepta tráfico de la inmediatamente anterior, y ningún componente de datos tiene ruta de salida a Internet.

Amenaza	Control principal	Control de respaldo
Robo de credencial	Authorization Code con PKCE y segundo factor adaptativo.	Detección de reutilización del token de refresco y revocación central.
Robo de token por inyección de script	Token en memoria, política de seguridad de contenido estricta.	Token de vida corta y cookie HttpOnly para el refresco.
Suplantación en la vinculación	Detección de vida y comparación facial separadas.	Validación documental y revisión manual del caso dudoso.
Interceptación del tráfico	TLS 1.3 y fijado de certificado en el canal móvil.	mTLS entre servicios y red privada sin salida.
Acceso indebido a la cuenta de otro	Autorización a nivel de objeto en el servicio de dominio.	Registro de todo acceso y alerta por patrón anómalo.
Transferencia fraudulenta	Motor de límites y evaluación de riesgo antes de ejecutar.	Segundo factor por monto y notificación inmediata por dos canales.
Alteración de la evidencia	Bitácora de solo anexo con hash encadenado.	Bloqueo de objeto y verificación programada de la cadena.
Compromiso del dispositivo	Escudo de integridad que bloquea la operación transaccional.	Credencial en el enclave seguro, no exportable.
Abuso automatizado	Límite de tasa por usuario y por operación, reglas de bots.	Alarma por desviación del patrón normal de uso.

Vista de seguridad: zonas de confianza y controles

Defensa en profundidad, del borde público al dato en reposo



El principio rector es el menor privilegio aplicado por capa: cada zona solo acepta tráfico de la zona inmediatamente anterior, y ningún componente de datos tiene ruta de salida a Internet.

Figura 22. Zonas de confianza y controles de seguridad

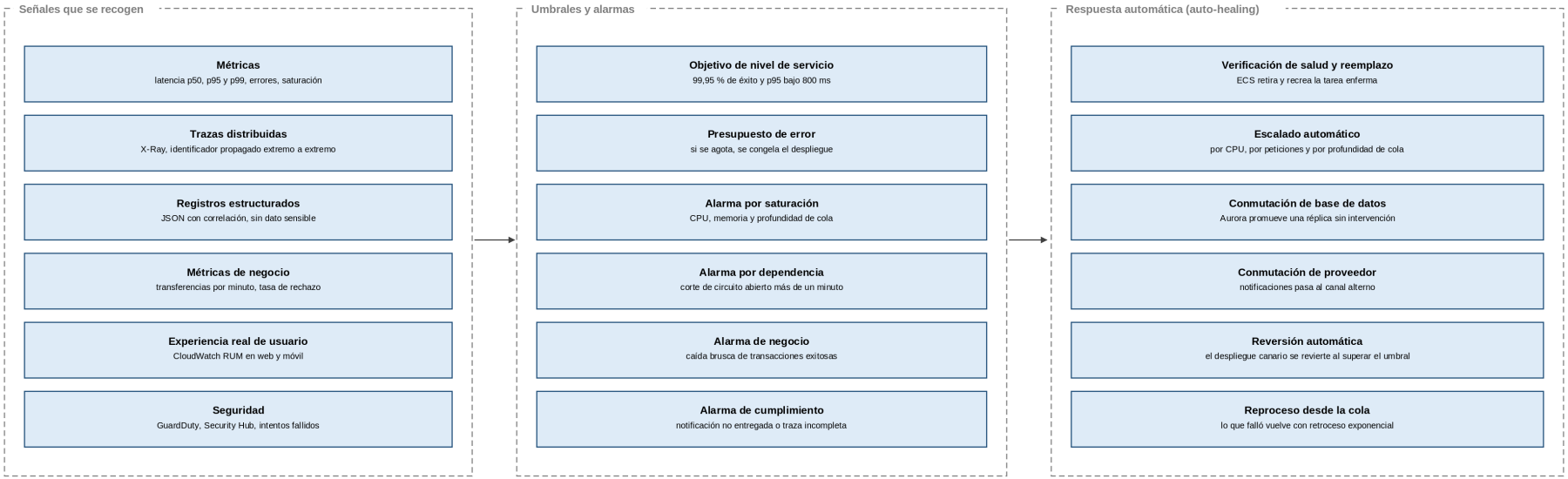
19. Observabilidad, excelencia operativa y auto-reparación

Las alarmas se definen sobre indicadores de servicio percibidos por el cliente (latencia y tasa de error frente al objetivo comprometido) y no sobre consumo de recursos. El uso alto de procesador sin degradación de latencia no constituye un incidente y no genera alarma.

Capacidad	Cómo se implementa
Monitoreo	Métricas, trazas distribuidas y registros estructurados, todos correlacionados por un identificador que se propaga extremo a extremo, incluidos los eventos.
Objetivos de nivel de servicio	Definidos por servicio con su presupuesto de error. Cuando el presupuesto se agota, la prioridad pasa de entregar funcionalidad a estabilizar.
Auto-reparación	Verificación de salud con reemplazo de tarea, escalado automático por demanda, conmutación de base de datos, conmutación de proveedor de notificaciones y reversión automática del despliegue canario.
Excelencia operativa	Infraestructura como código, despliegue canario con reversión automática, runbook por alarma, guardia rotativa y análisis posterior sin señalar culpables.
Gestión de incidentes	Severidad definida, comunicación al negocio y reporte al supervisor cuando el incidente afecta la disponibilidad del canal.

Observabilidad, excelencia operativa y auto-reparación

Qué se mide, qué se dispara y qué se corrige sin intervención humana



Criterios que rigen el modelo de alarmas

- Las alarmas se definen sobre síntomas percibidos por el cliente y no sobre causas: el uso de procesador al 90 % sin variación de latencia no genera alarma.
- El presupuesto de error convierte la disponibilidad en una decisión de negocio: cuando se agota, la prioridad pasa de entregar a estabilizar.
- Toda alarma tiene un runbook asociado y un responsable. Las alarmas sin acción definida se retiran en la revisión mensual del modelo.

Figura 23. Observabilidad, alarmas y respuesta automática

20. Marco normativo y estándares aplicables

Un diseño de banca digital que no nombra su marco normativo es un diseño incompleto: buena parte de los requisitos no funcionales no nacen del negocio sino de la norma.

20.1 Protección de datos personales

Norma o principio	Qué exige	Cómo lo cumple la arquitectura
Minimización	Tratar solo el dato necesario para la finalidad.	El BFF recorta campos por canal; los registros no llevan dato sensible en claro.
Consentimiento y finalidad	Registrar para qué se autorizó cada tratamiento.	Preferencias de contacto y autorizaciones versionadas en el Servicio de Clientes.
Derechos del titular	Acceso, rectificación, supresión y portabilidad.	API de consulta sobre la bitácora y exportación del perfil en formato legible.
Trazabilidad del acceso	Saber quién accedió a qué dato y cuándo.	Toda lectura de dato de cliente genera un evento de auditoría.
Datos biométricos	Categoría especial, con base legal y resguardo reforzado.	Evidencia cifrada con llave dedicada, retención acotada y acceso restringido por rol.
Transferencia internacional	Control sobre dónde reside el dato.	Región principal y secundaria definidas de forma explícita; sin réplica fuera de ellas.

20.2 Estándares de seguridad y de industria

Estándar	Alcance	Aplicación en este diseño
PCI DSS 4.0.1	Datos de tarjeta de pago.	Segmentación de red por zonas, cifrado en tránsito y reposo, registro de todo acceso, gestión de vulnerabilidades y autenticación multifactor para acceso administrativo.
ISO/IEC 27001 y 27002	Sistema de gestión de seguridad de la información.	Controles de acceso por rol, gestión de llaves y secretos, registro y monitoreo, gestión de incidentes.
ISO/IEC 27017 y 27018	Seguridad y privacidad en servicios de nube.	Responsabilidad compartida documentada, cifrado con llaves gestionadas por el banco, aislamiento de red.
ISO 22301	Continuidad del negocio.	Objetivos de tiempo y punto de recuperación por servicio, segunda región y prueba trimestral documentada.
ISO 20022	Mensajería financiera.	Formato de los mensajes hacia la red interbancaria.
OWASP Top 10 y API Security Top 10	Vulnerabilidades de aplicación y de interfaz.	Reglas de WAF, validación de entrada, control de autorización por objeto, límite de tasa y análisis estático y dinámico en el canal de despliegue.
OWASP ASVS y MASVS	Verificación de aplicación web y móvil.	Lista de verificación de las pruebas de seguridad antes de cada liberación mayor.
NIST SP 800-63 y FIDO2	Identidad digital y autenticación.	Niveles de garantía de identidad en la vinculación y de autenticación en el acceso; credencial ligada al dispositivo.
NIST CSF 2.0	Marco de ciberseguridad.	Organiza los controles en gobernar, identificar, proteger, detectar, responder y recuperar.

Sobre la jurisdicción: el enunciado no indica el país de la entidad. El diseño se sostiene sobre estándares internacionales, que son los exigibles en cualquier plaza, y deja declarado que la normativa local de protección de datos y la del supervisor bancario correspondiente se incorporan una vez confirmada la jurisdicción. Se registra como punto abierto en lugar de resolverse por suposición.

21. Manejo de costos

El ejercicio indica que hay presupuesto, lo que no exime de justificar el gasto. La arquitectura aplica tres criterios de costo y los hace medibles desde el primer día.

21.1 Criterios aplicados

Criterio	Cómo se aplica	Efecto esperado
Pagar por perfil de carga, no por moda	Carga sostenida en contenedores con compromiso de uso; carga irregular en servicios de pago por uso.	Evita pagar invocaciones en el piso sostenido y capacidad reservada en los picos.
Procesar cerca del dato	La analítica se ejecuta donde reside el dato; no se mueven volúmenes entre regiones de forma recurrente.	La transferencia de salida es uno de los costos que más crece sin que nadie lo note.
Niveles de almacenamiento por antigüedad	Movimientos recientes en caliente; archivo legal en almacenamiento frío con transición automática.	La retención regulatoria es larga; el costo por gigabyte decide la factura a tres años.
Caché antes que más capacidad	El perfil frecuente y las consultas idempotentes se sirven de caché.	Reduce llamadas al Core, que es el recurso más caro y menos elástico.
Apagar lo que no se usa	Ambientes de desarrollo y pruebas con horario; la región secundaria en capacidad mínima.	Los ambientes que no son producción suelen ser un tercio de la factura.
Atribuir para poder reducir	Etiquetado obligatorio por servicio y por dominio, presupuestos con alerta y revisión mensual.	Sin atribución por servicio, el gasto no se puede asignar a un responsable ni reducir con criterio.

21.2 Dónde está el costo y qué lo hace crecer

Componente	Peso relativo	Qué lo hace crecer	Palanca principal
Cómputo de servicios	Alto	Número de servicios y tamaño de tarea.	Dimensionar con datos reales y comprometer uso.
Bases de datos	Alto	Réplicas, retención y respaldo entre regiones.	Separar lectura y archivar lo frío.
Transferencia de datos	Medio y creciente	Tráfico entre zonas y salida a Internet.	Procesar cerca del dato y usar CDN.
Verificación de identidad	Medio	Precio por verificación en la vinculación.	Filtrar antes de llamar al proveedor.
Notificaciones	Medio	Volumen por norma y segundo proveedor.	Preferir push sobre SMS cuando el canal esté disponible.
Observabilidad	Bajo pero sorpresivo	Retención de registros y cardinalidad de métricas.	Muestreo de trazas y retención escalonada.
Almacenamiento legal	Bajo por unidad, alto en el plazo	Años de retención obligatoria.	Transición automática a niveles fríos.

La notificación por SMS merece atención aparte: es de los pocos costos que escala uno a uno con las transacciones del banco y no baja con la optimización técnica. Privilegiar el canal push cuando el cliente tiene la app instalada, dejando el SMS como alterno, es la decisión de arquitectura con mayor impacto directo en la factura.

22. Registro de decisiones de arquitectura

Veintitrés decisiones, cada una con las opciones que se evaluaron y con **tres justificaciones**, por encima del mínimo de dos que pide el ejercicio. Las justificaciones son de fondo: por qué esta opción resuelve mejor una restricción concreta del caso, no por qué es popular.

> *Criterio de desempate usado en todo el registro: ante dos opciones comparables se prefiere la que **reduce el acoplamiento**, la que **deja rastro auditable** y la que **el equipo puede operar**. En banca, una opción técnicamente superior que nadie puede sostener en producción es una opción peor.*

AD-01. Nube: AWS

Opciones evaluadas	Azure; Google Cloud; nube privada del banco
Justificación 1	Madurez del catálogo para los tres puntos críticos del caso en un solo proveedor: verificación facial con detección de vida, bitácora inmutable con bloqueo de objeto y base de datos global con rezago menor a un segundo. Resolverlos con un proveedor evita integrar tres contratos y tres modelos de identidad.
Justificación 2	Presencia regional y madurez operativa en banca latinoamericana, lo que reduce la latencia hacia el cliente final y acorta la curva de contratación de soporte y de talento.
Justificación 3	El diseño se mantiene portable: contenedores sobre ECS Fargate y no funciones propietarias en el núcleo del dominio, con infraestructura declarada en Terraform. La dependencia fuerte se concentra en servicios de borde y de datos, que son los que compensan el bloqueo.

AD-02. Framework móvil: Flutter

Opciones evaluadas	React Native; .NET MAUI; desarrollo nativo separado
Justificación 1	Un solo motor de render propio garantiza que la interfaz se vea y se comporte igual en iOS y Android. En banca esto importa más que en otros dominios: una diferencia de comportamiento entre plataformas en una pantalla de transferencia es un incidente, no un detalle estético.
Justificación 2	Rendimiento compilado a código nativo con arranque predecible, frente al puente de JavaScript de React Native, que añade latencia justo en las pantallas con animación y lista larga, que son las de movimientos.
Justificación 3	Ecosistema maduro de biometría, almacén seguro y fijado de certificado, con acceso directo a las interfaces nativas cuando haga falta, que es exactamente lo que exige el onboarding facial.
Nota	React Native sería la alternativa si el equipo ya fuera de React y se quisiera compartir lógica con la web; .NET MAUI solo se justificaría en una casa .NET consolidada.

AD-03. SPA web: Angular

Opciones evaluadas	React; Vue; renderizado en servidor con Next.js
Justificación 1	Marco completo y opinado: enrutamiento, formularios reactivos, inyección de dependencias y cliente HTTP vienen incluidos y versionados juntos. En banca, donde la aplicación vive diez años y rota de equipo, eso reduce la deriva arquitectónica frente a ensamblar librerías.
Justificación 2	TypeScript estricto por omisión y formularios reactivos con validación tipada, que es la mayor parte del trabajo de una banca en línea: formularios con reglas.
Justificación 3	Ciclo de versiones predecible y herramientas de actualización asistida, importante en un sistema que debe mantenerse al día por cumplimiento de vulnerabilidades.

AD-04. Flujo OAuth 2.0: Authorization Code con PKCE

Opciones evaluadas	Implicit; Resource Owner Password Credentials; Client Credentials; Device Code
Justificación 1	La SPA y la app móvil son clientes públicos: no pueden custodiar un secreto, porque el código es inspeccionable. PKCE sustituye ese secreto por un verificador efímero que nunca viaja en la redirección, de modo que interceptar el código de autorización no basta para canjearlo.
Justificación 2	El flujo implícito está formalmente desaconsejado desde las guías de buenas prácticas de seguridad de OAuth 2.0 y queda excluido de OAuth 2.1: devuelve el token en la URL, donde queda expuesto al historial, al referer y a los registros del servidor.
Justificación 3	ROPC obliga a que la aplicación vea la contraseña del cliente, lo que impide el segundo factor y la federación, y también queda fuera de OAuth 2.1. Client Credentials no aplica porque no hay usuario final, y Device Code resuelve otro problema: dispositivos sin teclado.
Nota	Se complementa con Pushed Authorization Requests y rotación del token de refresco con detección de reutilización.

AD-05. Entrada: API Gateway más un BFF por canal

Opciones evaluadas	Gateway único sin BFF; un BFF compartido; GraphQL en el borde
Justificación 1	Las necesidades de la web y del móvil divergen de forma estable: el móvil requiere menos campos, tolera peor la latencia y suma atestación del dispositivo. Un contrato único obliga a sobreservir a uno de los dos canales de forma permanente.
Justificación 2	Aísla el ritmo de cambio: una pantalla nueva cambia su BFF y ningún servicio de dominio se entera. Sin BFF, cada ajuste de interfaz presiona al dominio y se termina contaminando con lógica de presentación.
Justificación 3	El gateway conserva una sola responsabilidad: autenticar, proteger y enrutar. Mezclar composición en el gateway es cómo se convierte en un bus con lógica de negocio.
Nota	GraphQL se descarta por el costo de control de seguridad sobre consultas arbitrarias en un entorno regulado, y por la dificultad de limitar tasa por costo de consulta.

AD-06. Servicios de dominio desacoplados, no microservicios finos

Opciones evaluadas	Monolito modular; microservicios por entidad; servicios por capa
Justificación 1	La frontera se trazó por contexto delimitado y por ritmo de cambio, no por tamaño: transferencias cambia por regulación de pagos, onboarding por normativa de identidad y movimientos por rendimiento. Son tres razones de cambio distintas, luego tres servicios.
Justificación 2	Cada servicio es dueño de su almacenamiento, lo que permite elegir la tecnología adecuada a cada acceso y escalar de forma independiente la consulta de movimientos, que concentra el tráfico, sin arrastrar a transferencias.
Justificación 3	No se fragmenta más de lo necesario: siete servicios son operables con el equipo previsto. Microservicios por entidad multiplicaría la latencia de red y el costo operativo sin beneficio funcional.

AD-07. Protocolo: REST sobre HTTP/2 con mTLS interno

Opciones evaluadas	gRPC; GraphQL; SOAP; mensajería para todo
Justificación 1	REST con OpenAPI es legible, versionable y verificable por herramientas de seguridad de terceros, que es un requisito práctico cuando un auditor externo revisa las interfaces.

Justificación 2	El canal pasa por un gateway gestionado y por un WAF que inspeccionan HTTP; gRPC complica esa inspección en el borde y aporta su ventaja de rendimiento donde el cuello de botella no está en este caso.
Justificación 3	Para la comunicación entre servicios de dominio se usa mTLS con identidad de carga, de modo que la autenticación no depende solo de la red. gRPC queda disponible como optimización puntual si una ruta interna lo justifica por volumen.

AD-08. Mensajería: bus de eventos más colas de trabajo

Opciones evaluadas	Solo colas; Kafka autogestionado; llamadas síncronas encadenadas
Justificación 1	Separa dos semánticas distintas: el hecho de negocio se publica una vez y lo consumen varios interesados (notificaciones, auditoría, perfil frecuente), mientras que el trabajo diferido necesita entrega a un solo consumidor con reintento y cola de descarte.
Justificación 2	Encadenar llamadas síncronas acoplaría la transferencia a la disponibilidad del proveedor de notificaciones. Con eventos, el cliente recibe su confirmación aunque el envío del correo esté retrasado.
Justificación 3	Kafka autogestionado se descarta por costo operativo: el volumen de un banco de este perfil no justifica operar un clúster propio frente a servicios gestionados que cubren el mismo patrón.

AD-09. Persistencia: el motor se elige por patrón de acceso

Opciones evaluadas	Una sola base relacional compartida; todo NoSQL
Justificación 1	Clientes y transferencias son relacionales y exigen transacciones y restricciones de integridad: Aurora PostgreSQL con escritor y réplicas de lectura en varias zonas.
Justificación 2	La bitácora de auditoría es escritura intensiva, de clave conocida y de solo anexar: DynamoDB se ajusta mejor y escala sin ventanas de mantenimiento, con archivo en S3 para la retención legal.
Justificación 3	Una base compartida entre servicios reintroduce el acoplamiento que la descomposición buscó eliminar: dos servicios con esquema común no pueden desplegarse de forma independiente.

AD-10. Auditoría: bitácora de solo anexo con hash encadenado y bloqueo de objeto

Opciones evaluadas	Tabla relacional con disparadores; archivo de registro centralizado; libro mayor gestionado
Justificación 1	La exigencia no es guardar, es poder demostrar que nada se alteró. El hash encadenado hace detectable cualquier modificación retroactiva, y S3 Object Lock en modo cumplimiento impide borrar o sobrescribir incluso con credenciales de administrador.
Justificación 2	Separa consulta de conservación: DynamoDB atiende la búsqueda operativa del oficial de cumplimiento en milisegundos, y S3 conserva el archivo legal durante el plazo de retención a un costo por gigabyte mucho menor.
Justificación 3	Una tabla relacional con disparadores es modificable por quien tenga privilegios sobre el motor, y un archivo de registro centralizado está pensado para diagnóstico, no para prueba ante un regulador: rota, se trunca y no garantiza integridad.

AD-11. Clientes frecuentes: cache-aside con invalidación por evento

Opciones evaluadas	Read-through; expiración solo por tiempo; sesión pegajosa en memoria del proceso

Justificación 1	Cache-aside deja el control en el servicio: decide qué se cachea, con qué alcance y cuándo se invalida. Read-through acopla la caché al origen y complica aplicar reglas distintas por tipo de dato.
Justificación 2	La invalidación por evento, aplicando el patrón observador sobre el bus, reduce la ventana de dato obsoleto a segundos. Confiar solo en la expiración por tiempo obliga a elegir entre mostrar saldos viejos o perder el beneficio de la caché.
Justificación 3	La caché es distribuida y no local al proceso, de modo que cualquier instancia responde igual. La sesión pegajosa rompe el escalado horizontal y el reemplazo automático de tareas.
Nota	Se suman vista materializada para no recomponer el contexto en cada llamada, estrategia para la política de precarga y decorador para la degradación elegante.

AD-12. Transferencias: saga con compensación, outbox e idempotencia

Opciones evaluadas	Transacción distribuida en dos fases; confirmación eventual sin compensación
Justificación 1	La operación atraviesa el Core y la red interbancaria, que son sistemas sin transacción común. La saga declara por cada paso su compensación, de modo que un fallo tardío deja el sistema consistente y con rastro de ambas operaciones.
Justificación 2	La clave de idempotencia obligatoria en la petición evita el doble débito cuando el cliente reintenta por pérdida de red, que es el fallo más frecuente y más caro en banca móvil.
Justificación 3	El patrón outbox garantiza que el estado y su evento se guarden en la misma transacción: sin él aparecen transferencias registradas sin notificar, que es un incumplimiento normativo directo.

AD-13. Notificaciones: dos proveedores con conmutación y conciliación

Opciones evaluadas	Un proveedor con reintento; dos proveedores en reparto fijo
Justificación 1	La norma obliga a notificar, así que la notificación no entregada no es una degradación del servicio sino un incumplimiento. Un solo proveedor convierte su caída en una falla de cumplimiento del banco.
Justificación 2	El corte de circuito aísla al proveedor degradado y conmuta al alterno en segundos, sin esperar a que el reintento agote su ventana.
Justificación 3	El conciliador de entrega compara eventos notificables contra acuses recibidos y levanta lo que quedó sin notificar. Sin ese cierre, la conmutación da confianza falsa.

AD-14. Onboarding: servicio gestionado de biometría, con los controles separados

Opciones evaluadas	Construir el motor facial; comprar una suite cerrada de vinculación
Justificación 1	Construir detección de vida propia exige investigación continua contra ataques de presentación y de inyección que evolucionan cada mes. No es el negocio del banco y el riesgo de quedarse atrás es alto.
Justificación 2	Se separan en componentes distintos la prueba de vida, la comparación facial y la validación documental, porque son tres controles con tasas de error independientes. Una suite cerrada los funde y deja al banco sin capacidad de ajustar umbrales ni de cambiar un proveedor solo.
Justificación 3	El adaptador de biometría aísla al proveedor: cambiarlo es sustituir un componente, no rehacer el trámite.

AD-15. Alta disponibilidad multi-AZ y recuperación en segunda región

Opciones evaluadas	Una sola zona con respaldo; activo-activo multi-región
Justificación 1	Multi-AZ activo-activo cubre el fallo más probable, que es la pérdida de un centro de datos, con conmutación automática y sin pérdida de dato en los servicios transaccionales.
Justificación 2	Activo-activo entre regiones multiplicaría el costo y obligaría a resolver escritura concurrente distribuida sobre un Core que no la soporta. El beneficio marginal no justifica ni el costo ni el riesgo de corrupción.
Justificación 3	La segunda región se mantiene con capacidad mínima y datos replicados, y se levanta con las mismas plantillas de Terraform. La prueba de recuperación trimestral es la que convierte el plan en una capacidad real y no en un documento.

AD-16. Observabilidad sobre el stack nativo, con alarma por síntoma

Opciones evaluadas	Herramienta externa unificada; solo registros; alarma por recurso
Justificación 1	Métricas, trazas y registros nativos se integran con los servicios gestionados sin agentes adicionales y sin salida de datos a un tercero, lo que simplifica el análisis de privacidad que un banco debe hacer sobre toda herramienta que vea tráfico.
Justificación 2	Las alarmas se definen sobre indicadores percibidos por el cliente (latencia y tasa de error frente al objetivo de nivel de servicio) y no sobre consumo de recurso, lo que reduce el volumen de alertas sin impacto y mantiene la capacidad de reacción del equipo de guardia.
Justificación 3	El presupuesto de error convierte la disponibilidad en una decisión explícita: cuando se agota, la prioridad cambia de entregar funcionalidad a estabilizar.

AD-17. Costos: contenedores para carga sostenida y servicios gestionados para la variable

Opciones evaluadas	Todo serverless; todo en instancias reservadas; servidores propios
Justificación 1	La carga de banca en línea tiene un piso sostenido y predecible en horario laboral: ahí los contenedores con Savings Plans salen bastante más baratos que el pago por invocación.
Justificación 2	La carga irregular (vinculación, reportes, picos de notificación) sí va a servicios de pago por uso, porque pagar capacidad reservada para un pico de fin de mes es desperdicio puro.
Justificación 3	Se instrumenta desde el día uno: etiquetado obligatorio por servicio y por dominio, presupuestos con alerta y revisión mensual de dimensionamiento. Sin etiquetado, el gasto no se puede asignar por servicio ni priorizar su reducción.

AD-18. Descomposición: la frontera se traza por razón de cambio

Opciones evaluadas	Por capa técnica; por entidad de datos; por equipo; monolito con módulos
Justificación 1	Dos responsabilidades que cambian por motivos distintos y en momentos distintos deben poder desplegarse por separado. Transferencias cambia cuando cambia la regulación de pagos, onboarding cuando cambia la normativa de identidad y movimientos cuando cambia el rendimiento exigido: son tres relojes distintos.
Justificación 2	Cortar por capa técnica (una capa de controladores, otra de servicios, otra de datos) produce que cualquier cambio funcional atraviese las tres y obligue a desplegarlas juntas, que es exactamente lo contrario del desacoplamiento que el enunciado pide.
Justificación 3	Cortar por entidad de datos genera servicios anémicos que se llaman entre sí para completar una operación; multiplica la latencia y reparte una misma regla de negocio entre varios equipos, que es la peor forma de acoplamiento porque no se ve en el diagrama.

Nota	Las tres reglas operativas que se aplicaron: una sola razón para cambiar, nombres del dominio y no de la tecnología, y toda dependencia externa aislada en un componente dedicado.

AD-19. El token de acceso vive en memoria, no en almacenamiento del navegador

Opciones evaluadas	localStorage; sessionStorage; cookie accesible por script
Justificación 1	Todo lo que es legible por JavaScript es robable por una inyección de script. Guardar el token en almacenamiento local convierte cualquier vulnerabilidad de la web, propia o de una dependencia, en un robo de sesión bancaria completo.
Justificación 2	El token en memoria desaparece al recargar, y el refresco viaja en cookie HttpOnly con SameSite estricto: el script no puede leerla y el navegador no la envía desde otro sitio, con lo que se cubren a la vez el robo por inyección y la falsificación de petición entre sitios.
Justificación 3	El costo es un nuevo intercambio de token al recargar la página, que es imperceptible para el usuario y barato para el servidor. Es un intercambio claramente favorable frente al riesgo.

AD-20. Confianza cero dentro de la red: mTLS e identidad de carga de trabajo

Opciones evaluadas	Confianza por red (si está en la VPC, es confiable); llave compartida entre servicios; solo grupos de seguridad
Justificación 1	Estar dentro de la red privada no acredita identidad. Si un contenedor se compromete, la confianza por red le da acceso lateral a todo lo que alcance; con mTLS solo alcanza aquello para lo que su certificado está autorizado.
Justificación 2	La identidad por rol de tarea elimina las llaves estáticas, que son el hallazgo de auditoría más frecuente y más evitable en banca: no hay secreto que filtrar en una imagen, en una variable de entorno ni en el repositorio.
Justificación 3	Deja rastro atribuible: cada llamada interna queda registrada con qué carga de trabajo la hizo, no solo con qué dirección IP, lo que convierte el registro en evidencia utilizable en una investigación.

AD-21. Tres zonas de disponibilidad, no dos

Opciones evaluadas	Dos zonas; una zona con respaldo; cuatro o más zonas
Justificación 1	Con dos zonas, perder una deja el cincuenta por ciento de la capacidad y obliga a sobreaprovisionar al doble para sostener el pico. Con tres, perder una deja dos tercios y basta con un cincuenta por ciento de holgura: sale más barato tolerar el fallo.
Justificación 2	El quórum de los motores de datos y de los mecanismos de elección de líder requiere un número impar para resolver el escenario de partición de red sin ambigüedad. Con dos zonas, una partición deja a ambas sin saber cuál debe asumir el rol de escritor.
Justificación 3	Más de tres zonas añade costo de transferencia entre zonas y complejidad operativa sin mejorar de forma apreciable la probabilidad de disponibilidad para este perfil de carga.

AD-22. La auditoría se alimenta por evento asíncrono, no por llamada síncrona

Opciones evaluadas	Llamada síncrona a la API de auditoría; disparadores en la base de datos; escritura directa desde cada servicio
Justificación 1	Una llamada síncrona ata la operación de negocio a la disponibilidad de la auditoría: si el servicio de auditoría está lento, la transferencia se degrada. Y si se decide ignorar su fallo para no degradarla, aparecen operaciones sin rastro, que es precisamente lo que el requisito prohíbe.

Justificación 2	El patrón outbox resuelve la disyuntiva: el evento se escribe en la misma transacción que el cambio de estado, así que o se guardan los dos o ninguno, y la publicación posterior reintenta hasta lograrlo sin bloquear al cliente.
Justificación 3	Centralizar el sellado y el formato en un solo consumidor evita que cada servicio invente su propio esquema y su propio nivel de integridad, que es como una bitácora deja de ser comparable y deja de servir como prueba.

AD-23. La evidencia biométrica sube por URL prefirmada, no por el cuerpo de la petición

Opciones evaluadas	Carga a través del servicio de onboarding; carga al API Gateway; almacenamiento en la base de datos
Justificación 1	Un video de prueba de vida y las fotografías del documento pesan decenas de megabytes. Pasarlos por el gateway y por el servicio consume memoria y conexiones de componentes dimensionados para peticiones pequeñas, y choca con el límite de tamaño de carga del gateway.
Justificación 2	La URL prefirmada de corta vigencia hace que el dato de categoría especial viaje directo del dispositivo al almacenamiento cifrado, sin atravesar ni quedar en memoria de componentes intermedios. Menos lugares por donde puede filtrarse es menos superficie que auditar.
Justificación 3	El permiso queda acotado en objeto, operación y tiempo: la URL sirve para escribir un único objeto durante pocos minutos, y no concede ningún otro acceso al almacenamiento.

22.1 Verificación de cobertura de la justificación

El ejercicio pide que **cada** decisión arquitectónica tenga al menos dos justificaciones teóricas y las opciones evaluadas. Esta tabla es el inventario completo de las decisiones tomadas en el documento, para que la cobertura se pueda verificar de un vistazo y no haya que buscarla.

Grupo de decisión	Cuántas	Justificaciones	Dónde
Decisiones de arquitectura con registro formal	23	3 cada una (69 en total), con 2 a 4 opciones evaluadas	Sección 22, AD-01 a AD-23
Elección de tecnologías y servicios de nube	31	2 cada una, con la alternativa descartada	Sección 17
Frameworks de canal (web y móvil)	2	Tabla comparativa con a favor, en contra y veredicto por opción	Sección 10
Flujo de autenticación	1	3 justificaciones y 4 flujos descartados con su razón	Sección 11.1 y AD-04
Patrones de arquitectura	12	Dónde se aplica, por qué, y qué se descartó en cada uno	Sección 23.1
Patrones de diseño del mecanismo de clientes frecuentes	8	Clase que lo encarna y problema que resuelve	Sección 23.2 y figura 17
Servicios de la capa de integración añadidos	4	Responsabilidad y por qué existe, más 3 descartados	Sección 6.1
Protocolos y controles por tramo de comunicación	12	Protocolo, autenticación y cifrado por tramo	Sección 7.5

Suman **93 decisiones justificadas**, ninguna con menos de dos razones. Cuando una opción se descarta, se indica además el escenario en el que sí sería la elección correcta, para delimitar el alcance del descarte.

22.2 Cómo se construyó cada justificación

Las justificaciones de este registro se construyeron bajo cuatro reglas:

- **Se justifica contra una restricción del caso**, no contra una cualidad abstracta. No «es escalable», sino «la consulta de movimientos concentra el tráfico y debe escalar sin arrastrar a transferencias».
- **Se nombra el costo de la decisión**, no solo su beneficio. Elegir una nube concreta crea dependencia; elegir dos BFF duplica una capa. Una decisión sin costo declarado es una decisión que no se analizó.
- **Se dice qué se descartó y por qué**, incluyendo cuándo sí sería la opción correcta.
- **Se separa lo que se sabe de lo que se supone.** Los supuestos están marcados como tales en la sección 3.2, con qué pasaría si no se cumplen.

23. Patrones aplicados

23.1 Patrones de arquitectura

Patrón	Dónde se aplica	Por qué, y qué se descartó
API Gateway	Entrada única al sistema.	Concentra autenticación, límite de tasa y registro en un punto. Sin él, cada servicio reimplementa lo mismo con criterios distintos.
Backend for Frontend	Un BFF por canal.	La web y el móvil divergen de forma estable. Un contrato único obligaría a sobreservir a uno de los dos de forma permanente.
Capa anticorrupción	Adaptadores hacia el Core y el complementario.	El modelo del mainframe no contamina el dominio. Sin ella, cada cambio del Core se propaga por toda la plataforma.
Arquitectura orientada a eventos	Entre servicios de dominio.	Añadir un consumidor no obliga a tocar al productor. Encadenar llamadas síncronas acoplaría la transferencia a la disponibilidad del proveedor de notificaciones.
Saga con compensación	Transferencias.	No hay transacción común entre el Core y la red interbancaria. Dos fases se descartó porque bloquea recursos y el Core no lo soporta.
Outbox transaccional	Todo servicio que publica eventos.	Garantiza que el estado y su evento se guarden juntos. Sin él aparecen transferencias registradas sin notificar.
Idempotencia	Transferencias y consumidores de eventos.	El reintento por pérdida de red es el fallo más frecuente en móvil; sin clave de idempotencia produce doble débito.
CQRS	Lectura de movimientos y proyección de auditoría.	La consulta tiene forma distinta de la escritura. Se aplica solo donde paga; extenderlo a todo duplicaría modelos sin beneficio.
Cache-aside	Perfil frecuente y consultas repetidas.	El servicio controla qué cachea y cuándo invalida. Read-through acoplaría la caché al origen.
Base de datos por servicio	Cada servicio de dominio.	Permite desplegar por separado y elegir el motor adecuado. Una base compartida reintroduce el acoplamiento que la descomposición eliminó.
Corte de circuito y mamparo	Toda llamada saliente.	Un tercero lento agota los hilos y tumba la plataforma. El mamparo evita que una dependencia consuma los recursos de las demás.
Despliegue canario con reversión	Entrega continua.	Reduce el radio de impacto de un cambio. La ventana de mantenimiento no es aceptable en un canal que opera todo el día.

23.2 Patrones de diseño en el mecanismo para clientes frecuentes

El enunciado pide expresamente que esta pieza se resuelva con patrones de diseño y que se indique qué componentes interactúan. El nivel 4 (figura 17) lo muestra en detalle.

Patrón	Clase que lo encarna	Qué resuelve aquí
Fachada	ServicioPerfilFrecuente	Da una sola entrada al contexto del cliente y oculta la coordinación interna.
Cache-aside	GestorDeCache	Lee de caché y, si no está, consulta el origen y guarda. El servicio decide la política.
Observador	ObservadorDeCambios	Se suscribe al bus e invalida la entrada cuando el dato cambia, en vez de esperar a que expire.
Vista materializada	ContextoCliente	El contexto se arma una vez y se guarda completo, en lugar de recomponerlo en cada petición.

Patrón	Clase que lo encarna	Qué resuelve aquí
Estrategia	EstrategiaPrecarga y sus implementaciones	La política de precarga (frecuencia, recencia u horario) es intercambiable sin tocar el servicio.
Decorador	DegradadorElegante	Envuelve al gestor de caché: si Redis cae, la lectura sigue por el origen en lugar de fallar.
Repositorio	RepositorioOrigen	El dominio pide perfil y movimientos sin saber que detrás hay dos servicios distintos.
Constructor	ConstructorContexto	Arma el contexto por partes, de modo que nunca exista a medio construir.

24. Riesgos y mitigaciones

Riesgo	Impacto	Mitigación
El Core no soporta el volumen de consulta del canal digital.	Alto	Resolvedor de rango, caché, réplica para lo histórico, mamparo de conexiones y prueba de carga temprana contra el Core real.
Latencia del Core en hora pico degrada la experiencia.	Alto	Tiempo de espera agresivo con respuesta parcial marcada, y precarga del contexto del cliente frecuente.
Los dos proveedores de notificación fallan a la vez.	Alto, por in cumplimien to	Cola persistente que no pierde el aviso, conciliador que detecta lo no entregado y reporte de la brecha.
Falsos rechazos en la detección de vida frenan la vinculación.	Medio	Umbrales ajustables, camino de revisión manual y medición de la tasa de rechazo desde el primer día.
El sistema complementario no expone servicios.	Medio	El diseño ya contempla replicación por archivo como alternativa; el adaptador aísla la diferencia.
Crecimiento no controlado del costo de notificación por SMS.	Medio	Preferencia por canal push, con SMS como alterno, y presupuesto con alerta.
Deriva entre el BFF web y el BFF móvil hasta duplicar lógica.	Medio	La lógica de negocio vive en el dominio; se revisa en diseño que el BFF solo componga y recorte.
La región secundaria nunca se prueba y no sirve el día que haga falta.	Alto	Prueba de recuperación trimestral documentada, con resultado reportado al comité.
La bitácora de auditoría crece y encarece la consulta.	Medio	Separación entre bitácora operativa y archivo legal, con transición automática a almacenamiento frío.

25. Trazabilidad: requisito, decisión y vista

Cada requisito identificado en la sección 2 se rastrea hasta la decisión que lo resuelve y la vista donde se puede verificar.

Req.	Decisión principal	Dónde verificarlo
R1	Servicio de Movimientos con resolvedor de rango y caché.	Sección 7, figura 9; sección 14
R2	Servicio de Transferencias con saga, idempotencia y outbox (AD-12).	Sección 7, figura 10; sección 8, figura 16; sección 9, figura 20
R3	Servicio de Clientes con capa anticorrupción y fusionador (AD-09).	Sección 7, figura 8; sección 14
R4	Dos proveedores con conmutación y conciliación (AD-13).	Sección 7, figura 11; sección 15
R5	Angular para la web y Flutter para el móvil (AD-02, AD-03).	Sección 10; sección 7, figuras 3 y 4
R6	Authorization Code con PKCE (AD-04).	Sección 11; sección 7, figura 13; sección 9, figura 18
R7	Trámite con estado, controles separados de vida y rostro (AD-14).	Sección 12; sección 7, figura 12; sección 9, figura 19
R8	Bitácora de solo anexo con hash encadenado y bloqueo de objeto (AD-10).	Sección 13; sección 7, figura 14
R9	Cache-aside, observador, vista materializada, estrategia y decorador (AD-11).	Sección 23.2; sección 7, figura 15; sección 8, figura 17
R10	API Gateway que autentica, protege y enruta; BFF por canal (AD-05).	Sección 7, figuras 5, 6 y 7; sección 6
R11	Marco normativo y estándares aplicados por control.	Sección 21
R12	Multi-AZ activo-activo y segunda región con prueba trimestral (AD-15).	Sección 16, figura 21
R13	Observabilidad por síntoma, presupuesto de error y auto-reparación (AD-16).	Sección 19, figura 23; sección 18, figura 22
R14	AWS, con las palancas de baja latencia enumeradas (AD-01).	Sección 16.3, figura 21
R15	Servicios por contexto delimitado, eventos y adaptadores (AD-06, AD-08).	Secciones 6, 7 y 23
R16	Los cuatro niveles del modelo C4, etiquetados.	Secciones 5 a 8, figuras 1 a 17

25.1 Qué haría distinto con más información

- Confirmaría la jurisdicción para precisar plazos de retención, contenido de los avisos obligatorios y el supervisor al que se reportan los incidentes.
- Mediría el tiempo de respuesta real del Core bajo carga antes de comprometer los objetivos de latencia; hoy es un supuesto.
- Revisaría si el sistema complementario puede replicarse, lo que simplificaría la unificación del perfil.
- Dimensionaría el costo con volúmenes reales de transacción y de notificación, que es lo que decide la factura.

Los supuestos anteriores quedan registrados de forma explícita en la sección 3.2, junto con el efecto que tendría sobre el diseño el que alguno no se cumpla.